Seguridad, Rendimiento y Disponibilidad de Servicios e Infraestructuras

Ana I. González Acuña

Grado en Ingeniería Informática



2026/27

SRDSI

1. Introducción a la seguridad informática
2. Seguridad en la comunicación
3. Seguridad en los servicios
4. Seguridad Operacional



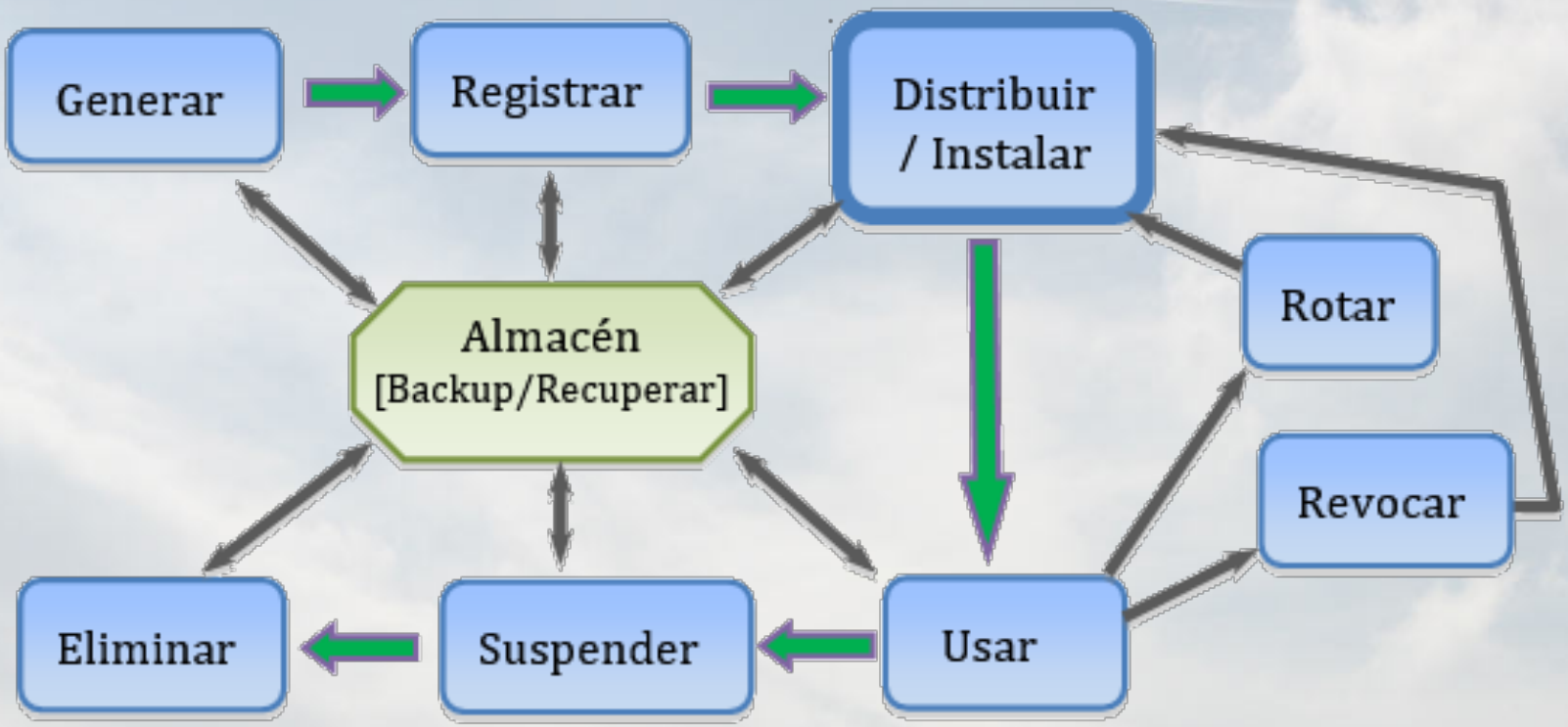
Tema 1: Introducción a la seguridad informática



1 Introducción a la seguridad informática
1.1 Conceptos básicos de seguridad informática
1.2 Introducción a la criptografía
1.3 Características comunicación segura
1.4 Gestión de claves.
- Establecimiento de claves
- Distribución de claves simétricas
- Distribución de claves asimétricas



Gestión de claves



Ciclo de vida de las claves criptográficas

Recommendation for Key Management- SP800-57

Distribución de claves

Problema:

- Simétrica: establecer una clave compartida.
- Asimétrica: validar una clave pública.



Distribución de claves

Problema:

- Simétrica: establecer una clave compartida.
- Asimétrica: validar una clave pública.

Solución:

- [Entrega en persona]
- (*Key Establishment*) Establecimiento seguro de claves simétricas
- (*Key Distribution*) Distribución basada en un intermediario de confianza (***T**rusted **T**hird **P**arty*)
  - Simétrica: Centro de distribución de claves (KDC)
  - Asimétrica: Certificado digital + PKI
    - ★ Modelo de confianza distribuida: Web of trust
    - ★ Modelo de confianza centralizada: Internet X.509 PKI



Protocolos para el establecimiento de claves simétricas (*Key establishment*)

- (*Key Transport*) Transporte de clave de sesión:

  A $\Longrightarrow$ B

  generar $\mathtt{Sim}_{AB}$



Protocolos para el establecimiento de claves simétricas (*Key establishment*)

- (*Key Transport*) Transporte de clave de sesión:

$$\begin{array}{ccc} \text{A} & \Longrightarrow & \text{B} \\ \text{generar } \mathtt{Sim}_{AB} & & \\ \mathtt{C} = \mathtt{Pub}_{\mathbf{B}}(\mathtt{Sim}_{AB}) & \xrightarrow{\mathtt{C}} & \mathtt{Sim}_{AB} = \mathtt{Priv}_{B}(\mathtt{C}) \end{array}$$



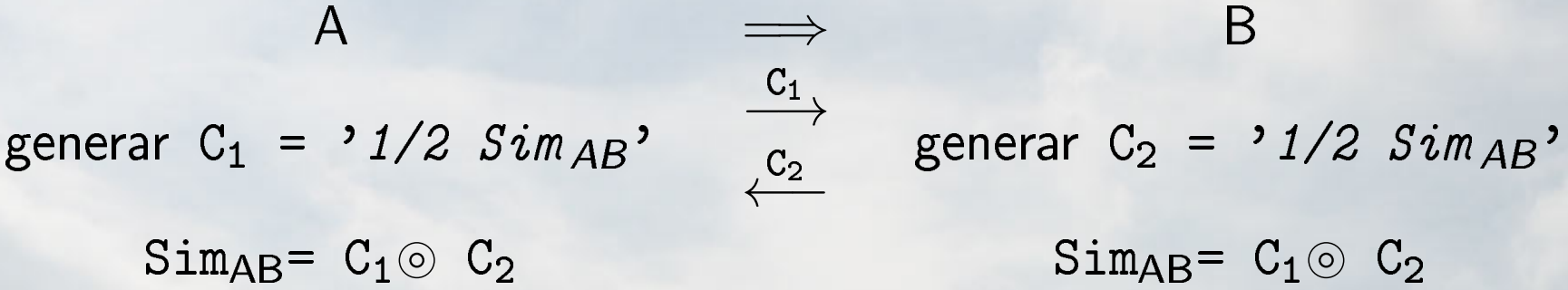
Protocolos para el establecimiento de claves simétricas (*Key establishment*)

- (*Key Transport*) Transporte de clave de sesión:

A		B
generar $\mathtt{Sim}_{AB}$		
$C = \mathtt{Pub}_B(\mathtt{Sim}_{AB})$	$\xrightarrow{C}$	$\mathtt{Sim}_{AB} = \mathtt{Priv}_B(C)$
$K = \mathtt{Pub}_B(A\|\|\mathtt{Sim}_{AB}),\ C = \{K, \mathtt{Priv}_A(K)\}$	$\xrightarrow{C}$	$\mathtt{Sim}_{AB} = \mathtt{Priv}_B(K)$



- (*Key Agreement or Key-Encapsulation Mechanism*) Acuerdo de clave de sesión



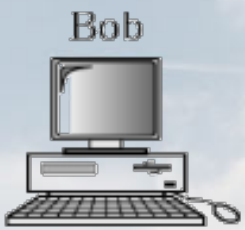
NIST SP 800 227_ Recommendations of Key-Encapsulation Mechanism



DIFFIE-HELMANN (no autenticado)



Alice y Bob conocen el valor de **N** y de **G**



Clave local: **a**

$I_{AB} = G^{a} \bmod N$

I_{AB} →

← I_{BA}

Clave local: **b**

$I_{BA} = G^{b} \bmod N$

$K_{AB}=(I_{BA})^{a} \bmod N$

$K_{AB}=(I_{AB})^{b} \bmod N$

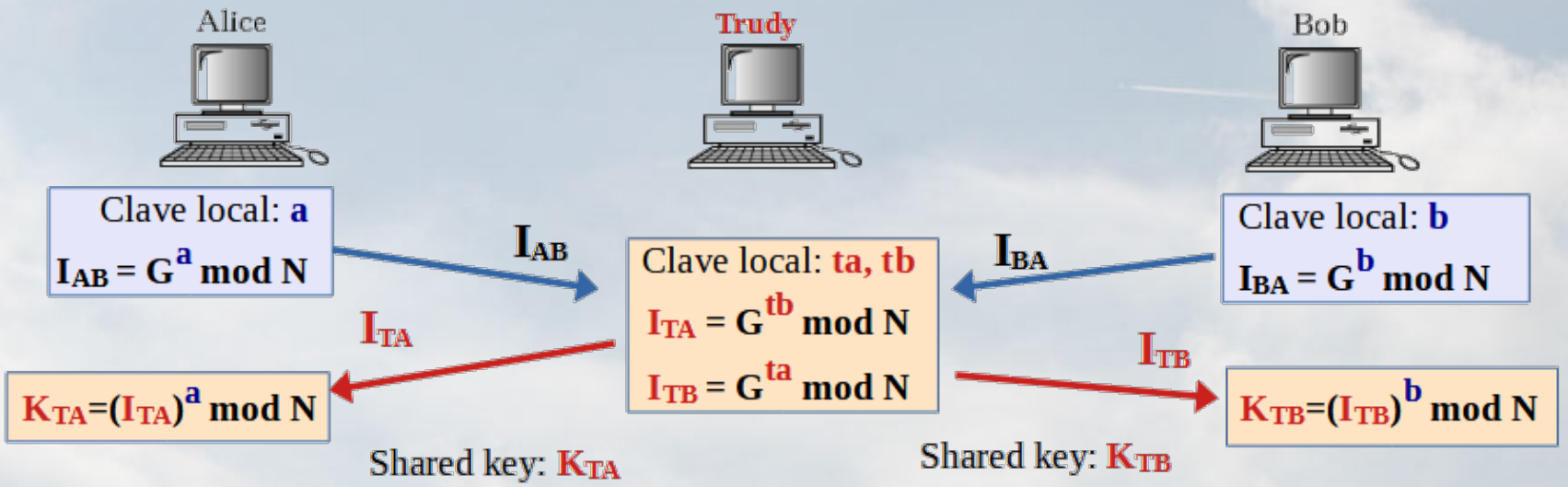
Shared key:

$K_{AB} = G^{ab} \bmod N$

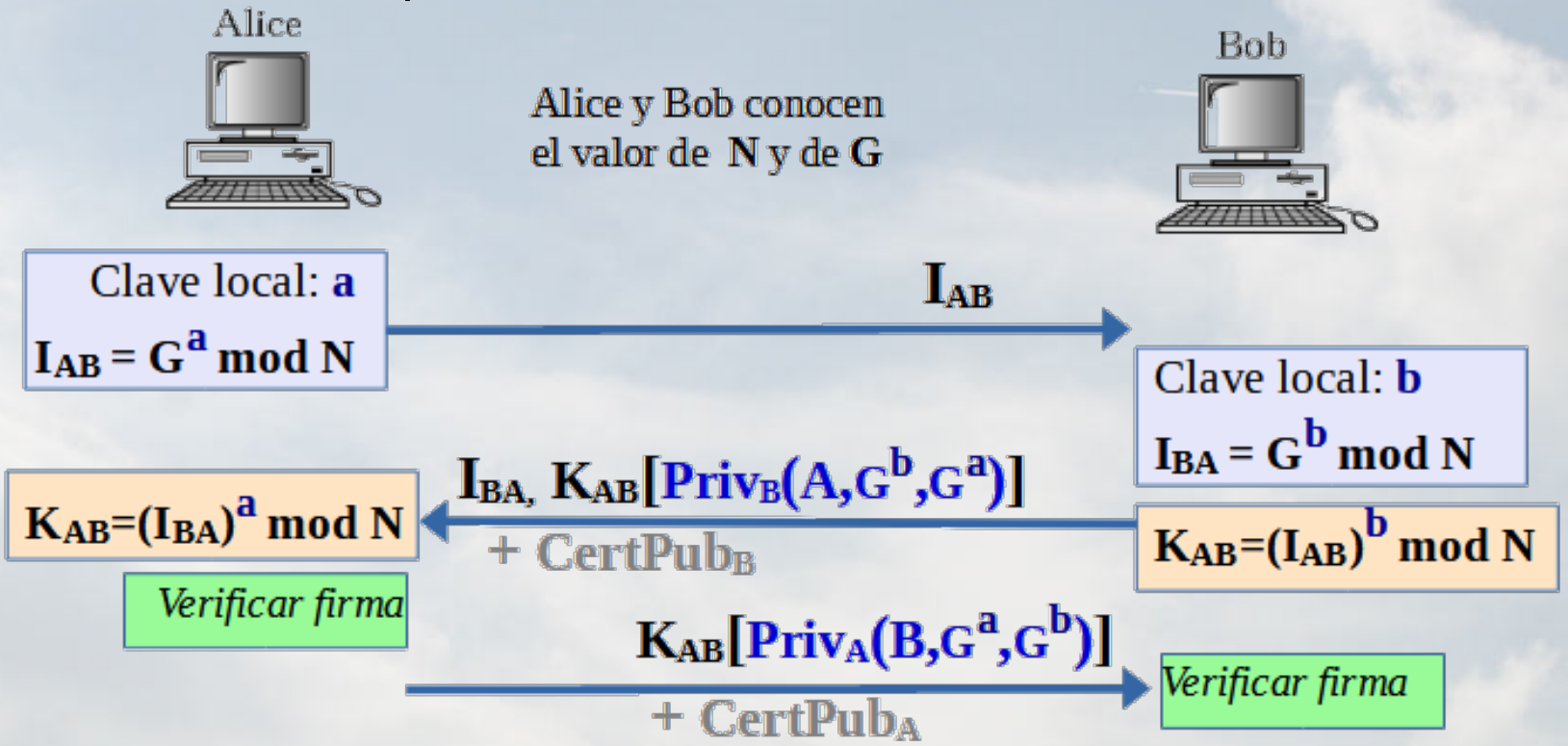
(RFC 2631)



MiM attack


Alice
Trudy
Bob
Clave local: a
$I_{AB} = G^{a} \bmod N$
I_{AB}
Clave local: ta, tb
$I_{TA} = G^{tb} \bmod N$
$I_{TB} = G^{ta} \bmod N$
I_{BA}
Clave local: b
$I_{BA} = G^{b} \bmod N$
I_{TA}
I_{TB}
$K_{TA}=(I_{TA})^{a} \bmod N$
$K_{TB}=(I_{TB})^{b} \bmod N$
Shared key: K_{TA}
Shared key: K_{TB}

Station-to-station protocol



Otros protocolos basados en DH con autenticación: STS-MAC, MQV, IKEv2, Oakley, SKEME, SIGMA...

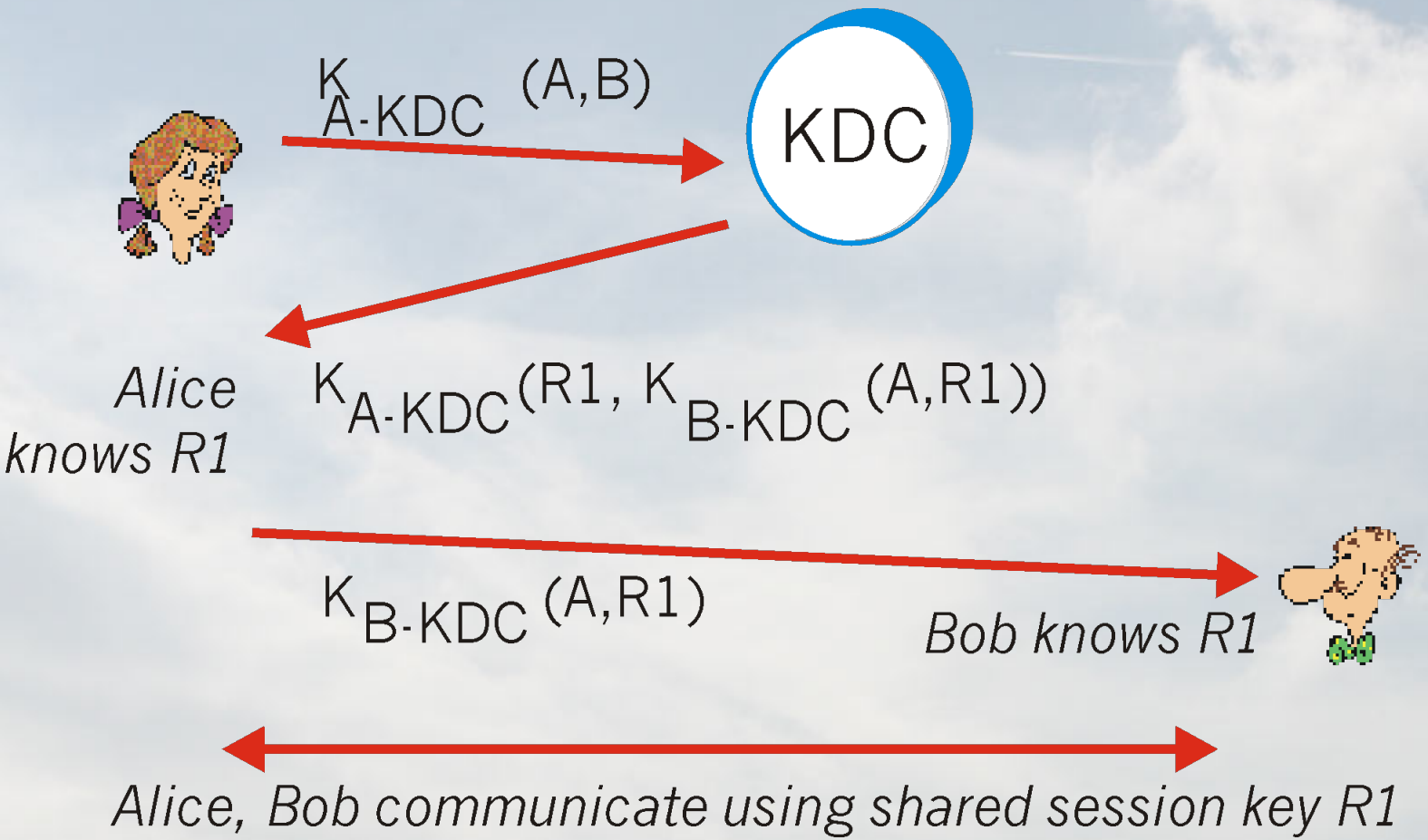
Book:Protocols for Authentication and Key Establishment (2019)

KDC (Key Distribution Center)

- Servidor en red de confianza para todas las entidades
  - Comparte una clave simétrica con cada entidad de la red, predistribuida a través de un canal seguro.
- Crea y distribuye una clave de sesión que va a ser utilizada en la conexión entre dos entidades.
- Ámbito redes locales



Protocolo básico (no seguro)



fuente: instructors.pearsonhighered.com

Kerberos (v5_RFC 4120-1)

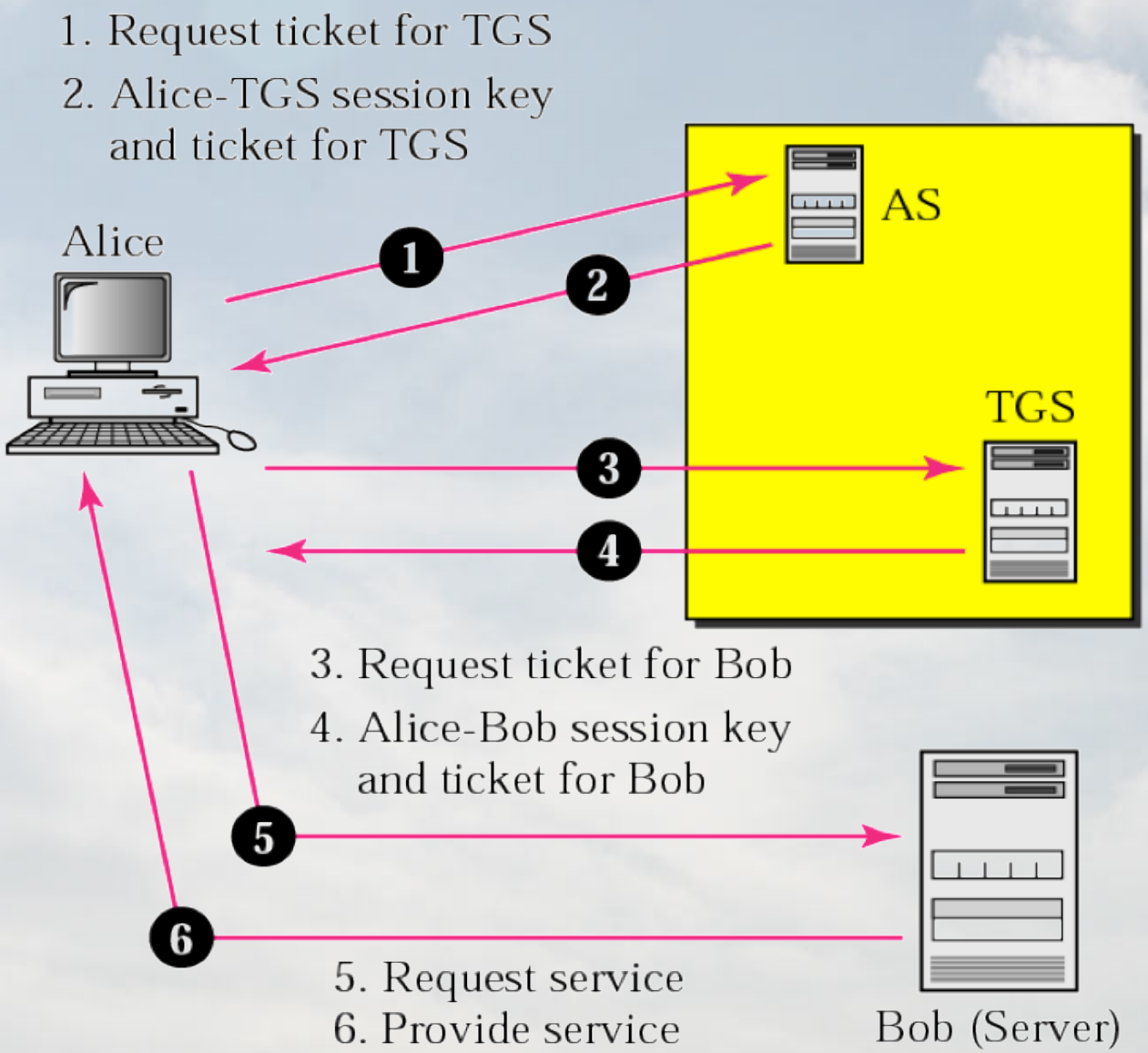
- Proyecto MIT, 1988 (RFC 1510, 1993)
- Incluye tres servidores (más al cliente):
  - *Authentication Server* (AS): Autentica a los usuarios durante la conexión (KDC).
  - *Ticket-Granting Server* (TGS): Autoriza los accesos a los recursos de cada servidor por parte de cada cliente
  - Servidor final, con el que quiere trabajar el cliente/usuario



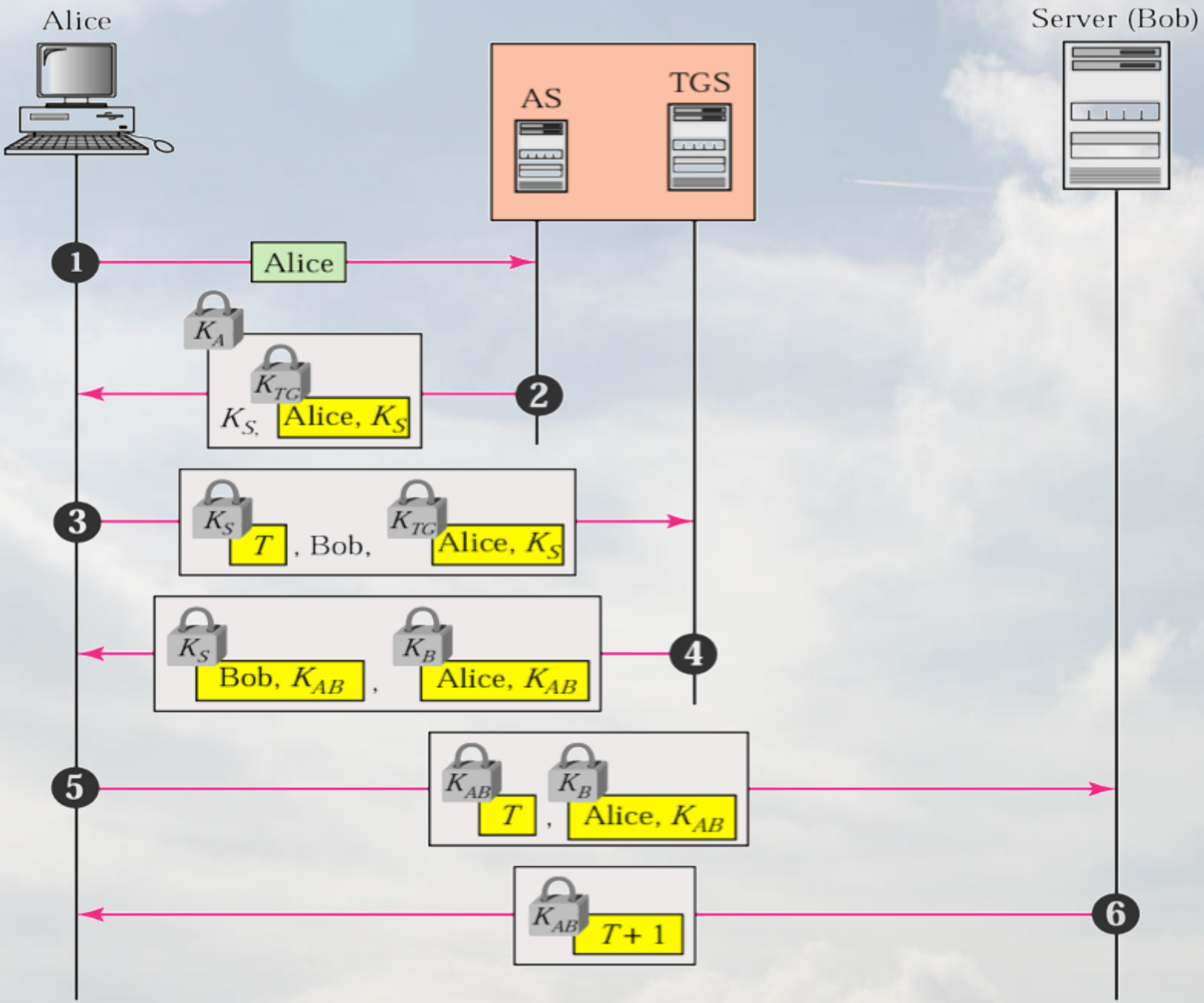
Kerberos (v5_RFC 4120-1)

- Proyecto MIT, 1988 (RFC 1510, 1993)
- Incluye tres servidores (más al cliente):
  - *Authentication Server* (AS): Autentica a los usuarios durante la conexión (KDC).
  - *Ticket-Granting Server* (TGS): Autoriza los accesos a los recursos de cada servidor por parte de cada cliente
  - Servidor final, con el que quiere trabajar el cliente/usuario
- Desventajas
  - Punto único de fallo, BD de claves
  - Pocos usuarios (decenas de miles)
  - Canal seguro durante la puesta en marcha
  - *Online* 24h





fuente: Crytography and Network Security. Forouzan



fuente: Crytography & Network Security. Forouzan

Certificado digital

Documento electrónico que asocia una **clave pública** (y otros datos) con la **identidad** de su propietario

- Contiene información sobre la identidad del propietario (nombre, dirección, correo), su clave pública (+ atributos de la clave pública) y una **firma digital** de una entidad intermediaria de confianza: **autoridad de certificación** (CA)
- Formato básico:
  $\mathtt{Cert}_A = [\mathtt{Pub}_A, \mathtt{ID}_A, \mathtt{Priv}_{CA}(\mathtt{Pub}_A, \mathtt{ID}_A)]$
- Tipos:
  - X.509 (p.e. DNIe...)
  - PGP
- Soporte: software (archivo, nube) o hardware (USB, *smart card* ...)



Public Key Infrastructure (PKI)

Public-**K**ey **I**nfrastructure: una infraestructura compleja compuesta por hardware, software, personas, políticas y procedimientos necesarios para crear, gestionar, almacenar, distribuir y revocar **certificados digitales** basados en criptografía de clave pública en un entorno de red.

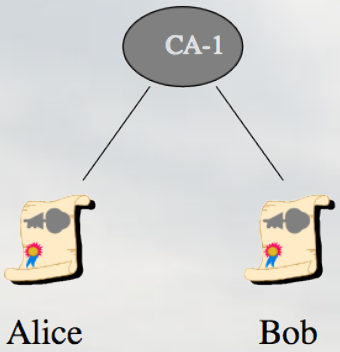


Public Key Infrastructure (PKI)

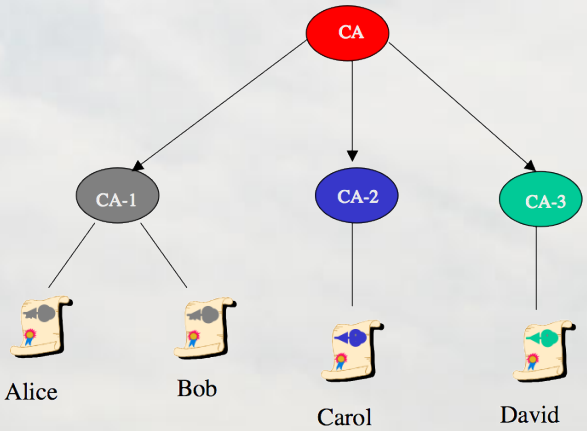
Public-**K**ey **I**nfrastructure: una infraestructura compleja compuesta por hardware, software, personas, políticas y procedimientos necesarios para crear, gestionar, almacenar, distribuir y revocar **certificados digitales** basados en criptografía de clave pública en un entorno de red.

- Modelos de confianza en PKI (RFC 4158: Overview of PKI Structures)

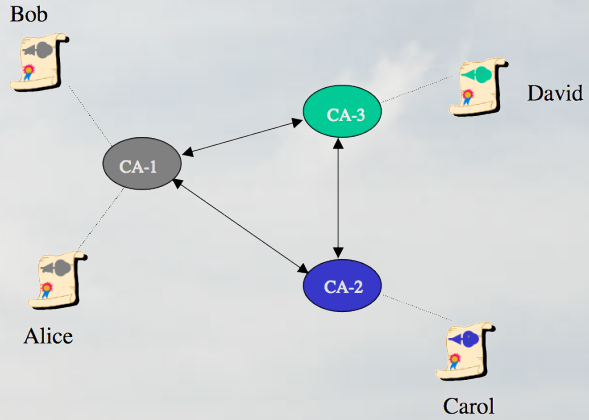
Centralizado



Jerárquico



Malla(mesh)



fuente: csrc.nist.gov/groups/ST/crypto_apps_infra/documents/B2B-article.pdf

Jerárquico

- Relación entre CAs : subordinación a superior (unidireccional)
- Usuarios confían en la CA raíz.
- Caminos de certificación/validación comienzan en la CA raíz
- Ventajas:
  - Escalabilidad, fácil incorporar nuevas CA
  - Creación camino de certificación sencillo (determinista)
  - Camino de certificación corto (profundidad árbol)
  - Certificados más pequeños
- Desventajas:
  - CA raíz comprometida –> toda la PKI comprometida (no hay solución)
  - Acuerdo en una única CA raíz puede ser políticamente imposible



Malla (*Mesh*-PKI)

- Relación *peer to peer* entre CAs (bidireccional)
- Usuarios confían en la CA que emitió su certificado
- Ventajas:
  - Fácil incorporar una nueva CA
  - CA comprometida –> no compromete toda la PKI, se elimina
- Desventajas:
  - Construcción camino de certificación más complejo (y no determinista)
  - Camino de tamaño máximo igual al número de CAs
  - Certificados más largos y complejos



Ejemplo: *Web of trust / User-centric trust*

- En PGP/GnuPG, siguiendo un modelo de confianza distribuido, descentralizado.
- Es el propio **usuario** el que **establece la confianza** en la validez de las claves públicas de otros usuarios
- Y actúa como una "CA", firmando claves públicas de otros usuarios –> **certificados PGP**/GnuPG.
- Desventajas del modelo:
  - Número de usuarios reducido (solución: *key servers*)
  - No tienen validez legal
  - Diferentes niveles de confianza



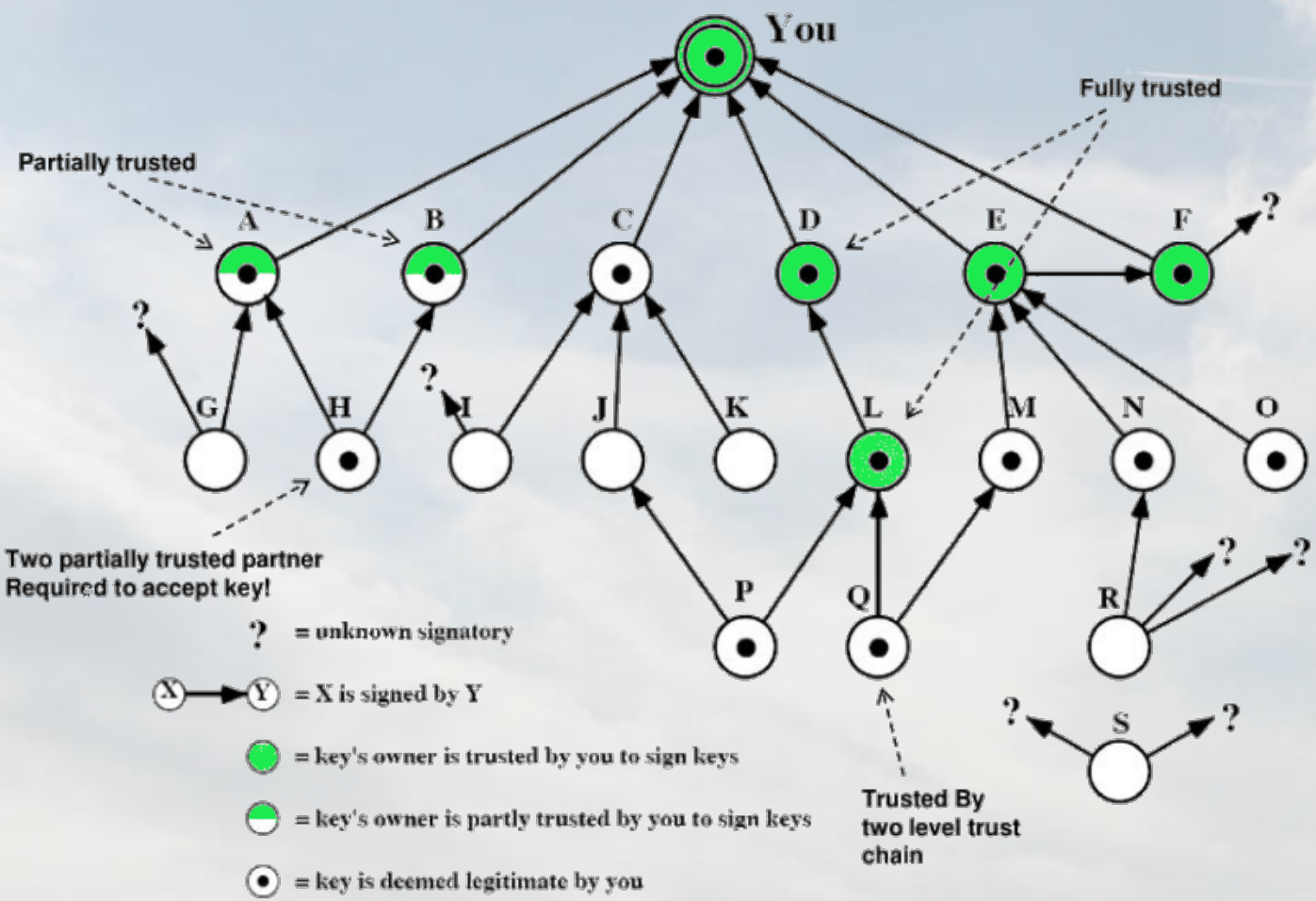
- Dos niveles de confianza:
  - **Validez de la clave**: Si se firma una clave pública, se valida solo esa clave pública.
  - **Confianza en el propietario** (*trust*): Si se confía en un usuario, se confía en las claves públicas firmadas por ese usuario (adquiere el papel de una CA) con distintos niveles. Subjetivo y local.

    https://www.linux.com/training-tutorials/pgp-web-trust-core-concepts-behind-trusted-communication/

    https://www.linux.com/news/pgp-web-trust-delegated-trust-and-keyservers/



Cadena de confianza basada en relaciones personales:

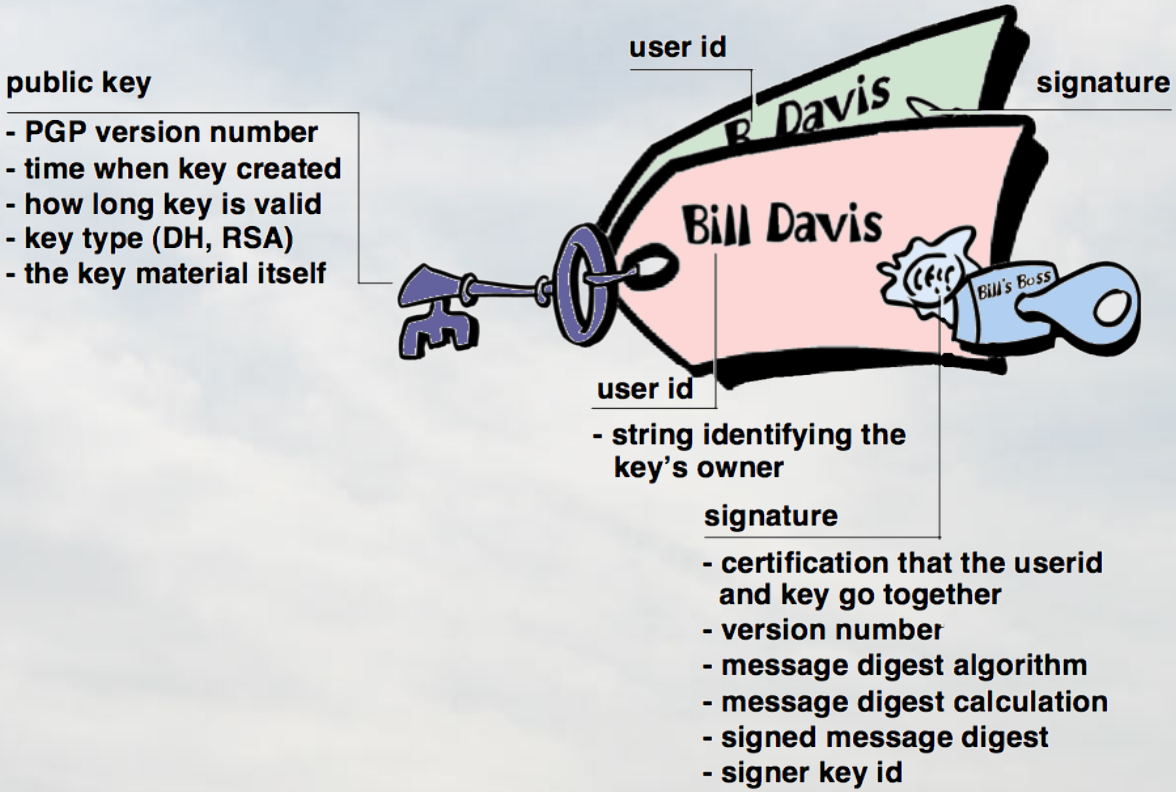


fuente: Phil Zimmerman



Certificados PGP/GnuPG

PGP utiliza un formato propio de certificado que es emitido por el propio usuario propietario de la clave pública, y firmado inicialmente por él mismo con su clave privada (*self-signature*)



fuente:ftp.pgpi.org/pub/pgp/6.5/docs/english/IntroToCrypto.pdf

LLaveros (anillos) de confianza

- PGP guarda las claves en dos archivos: *public keyring* y *private keyring*
- Cada clave pública tiene asociada información de confianza
- La **confianza en el propietario de una clave** servirá para validar una nueva clave pública si cumple dos condiciones:
  - si viene firmada por las suficientes claves válidas, lo que quiere decir
    - ★ que la hemos firmado nosotros personalmente,
    - ★ o está firmada por una clave de plena confianza,
    - ★ o está firmada por tres claves de confianza marginal;
  - y longitud del camino entre la clave nueva y nuestra clave es de cinco pasos o menos
- La longitud del camino, en número de claves con confianza marginal requeridas, y el número de claves con confianza plena requeridas son configurables.



Distribución claves PGP

PGP *Key servers*

- Repositorio de certificados PGP.
  - Tradicional (*Hockeypuck*): keyserver.ubuntu.com, pgp.mit.edu, pgp.surf.nl
    Se pueden revocar. Admite firmas de terceros. No se verifica clave.
    En 2019 los servidores sufrieron un ataque, firmaron miles de veces algunos certificados, aumentando su tamaño a varios megas. Al descargarlos inutiliza el *keyring*.
  - Moderno (*Hagrid*): keys.openpgp.org
    Borrable (RGPD). Elimina firmas de terceros. Verificación por correo electrónico

HTTP Keyserver protocol (HKP,HKPS): HTTP(s) en TCP 11371, para interactuar con servidores PGP



Web Key Directory (OpenPGP WKD)

- Protocolo para localizar claves OpenPGP de forma automática mediante la dirección de correo. WKD realiza solicitud HTTPS al servidor web del dominio receptor:
  `https://srdsi.lab/.well-known/openpgpkey/hu/iy9...n5q?l=user1`

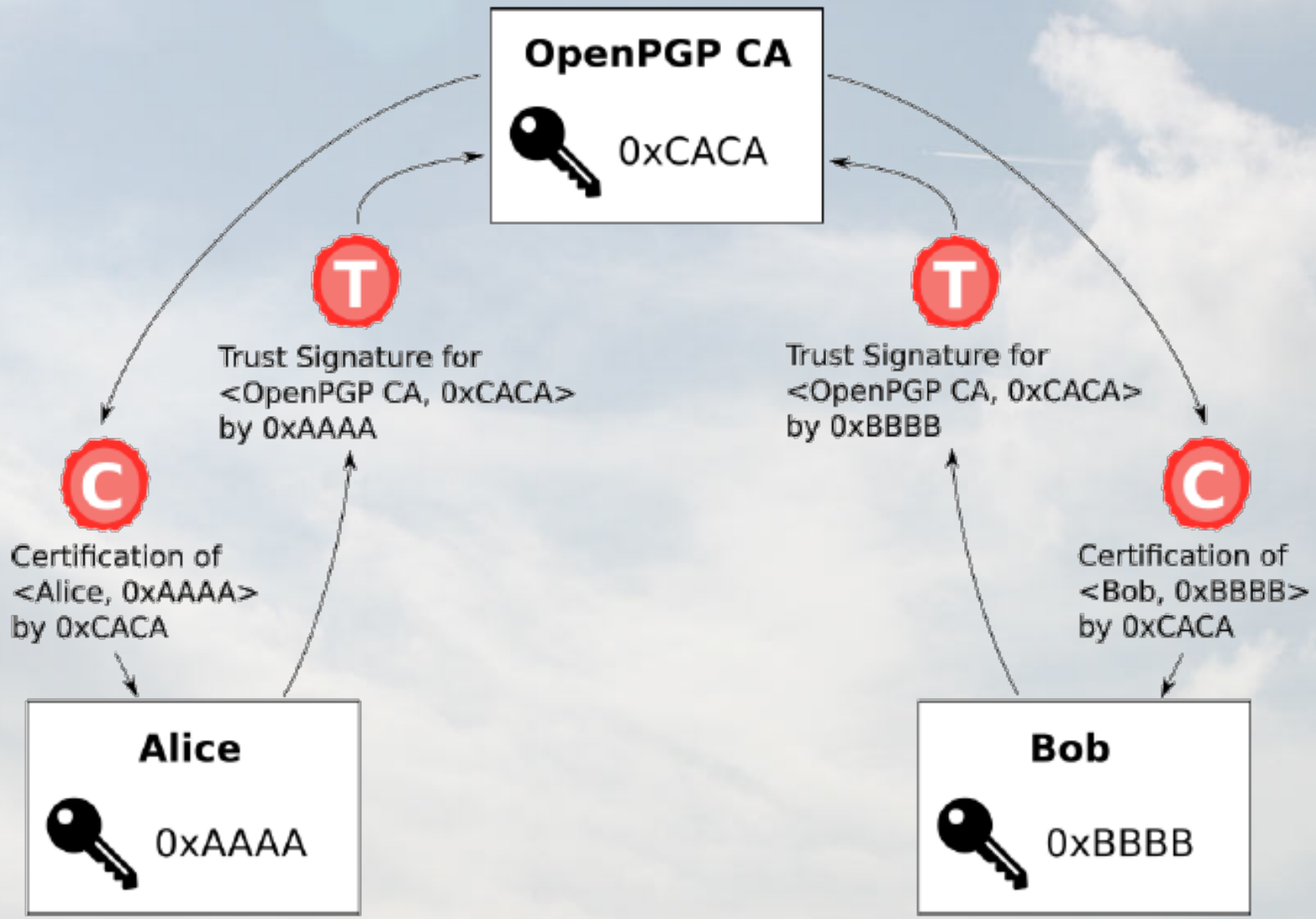
PGP Global directory:

- Servidor único operado comercialmente ($\in$ Symantec). Se requiere validación del propietario por email para gestionar su clave (autenticación). Ámbito empresarial, basado en LDAP(s).(más información)

OpenPGP CA

- Proyecto para la gestión de claves PGP en un entorno local:
  - Autenticar claves PGP
  - Publicar/distribuir claves mediante WKD o *keyservers*, mediante la asociación de la clave PGP y una dirección de correo.





fuente:https://openpgp-ca.org/background/details/

ACTIVIDAD: Gestión de claves con GnuPG

- Exportar clave pública a un fichero
  `gpg -a --output` *`publica.gpg`* `--export` *`claveID`*



ACTIVIDAD: Gestión de claves con GnuPG

- Exportar clave pública a un fichero
  `gpg -a --output` *`publica.gpg`* `--export` *`claveID`*
- Importar clave al llavero (tras validar *fingerprint*)
  `gpg --import` *`publica.gpg`*



ACTIVIDAD: Gestión de claves con GnuPG

- Exportar clave pública a un fichero
  `gpg -a --output` *`publica.gpg`* `--export` *`claveID`*
- Importar clave al llavero (tras validar *fingerprint*)
  `gpg --import` *`publica.gpg`*
- Distribuir clave pública a través de un servidor
  `gpg --keyserver` *`servename`* `--send-keys` *`claveID`*
  `{--search-keys, --recv-keys}`



ACTIVIDAD: Gestión de claves con GnuPG

- Exportar clave pública a un fichero
  `gpg -a --output` *`publica.gpg`* `--export` *`claveID`*
- Importar clave al llavero (tras validar *fingerprint*)
  `gpg --import` *`publica.gpg`*
- Distribuir clave pública a través de un servidor
  `gpg --keyserver` *`servename`* `--send-keys` *`claveID`*
  `{--search-keys, --recv-keys}`
- Revocar claves
  `gpg --output` *`revoc.asc`* `--gen-revoke` *`claveID`*
  `gpg --keyserver` *`servername`* `--send-keys` *`claveID`*



ACTIVIDAD: Gestión de claves con GnuPG

- Exportar clave pública a un fichero
  `gpg -a --output` *`publica.gpg`* `--export` *`claveID`*
- Importar clave al llavero (tras validar *fingerprint*)
  `gpg --import` *`publica.gpg`*
- Distribuir clave pública a través de un servidor
  `gpg --keyserver` *`servename`* `--send-keys` *`claveID`*
  `{--search-keys, --recv-keys}`
- Revocar claves
  `gpg --output` *`revoc.asc`* `--gen-revoke` *`claveID`*
  `gpg --keyserver` *`servername`* `--send-keys` *`claveID`*
- Firmar claves públicas
  `gpg --edit-key` *`claveID`* $\Rightarrow$ `gpg> sign`
- Asignar nivel de confianza al propietario: `gpg> trust`



Ejercicios

Como usuario `user1`:

1. Importar al llavero la clave pública de A.
2. Dada la clave pública de A: No firmarla y catalogar a A como "no confiable".
3. Recibir un archivo firmado por A. Verificar la firma ¿Qué mensaje muestra GnuPG?
4. Firmar la clave pública de A y catalogar a A como "confiable".
5. Volver a verificar la firma ¿Qué mensaje muestra ahora GnuPG?
6. Recibir un archivo firmado por B y su clave firmada por A. Verificar las firmas ¿Qué mensajes muestra GnuPG?
7. Importar al llavero la clave pública de B. No firmar. Nivel de confianza: "untrusted"
8. Recibir un archivo firmado por C y su clave firmada por B. Verificar las firmas ¿Qué mensajes muestra GnuPG?

Analizar los mensajes mostrados por GnuPG.



Ejemplo: Internet PKI / Web Model

Internet X.509-based Public Key Infrastructure (PKIX, RFC 5280, 6818, 4158, 4210, 6712 ...)

- Modelo de confianza jerárquico, en base a un conjunto de autoridades de certificación raíz (*Multi-rooted hierarchical PKI*)
- Dota de estructura a sus componentes
- Define estándares para los distintos protocolos y documentos
- Facilita el uso de certificados X.509 a los protocolos/aplicaciones de Internet (WWW, e-mail, IPSec ...)

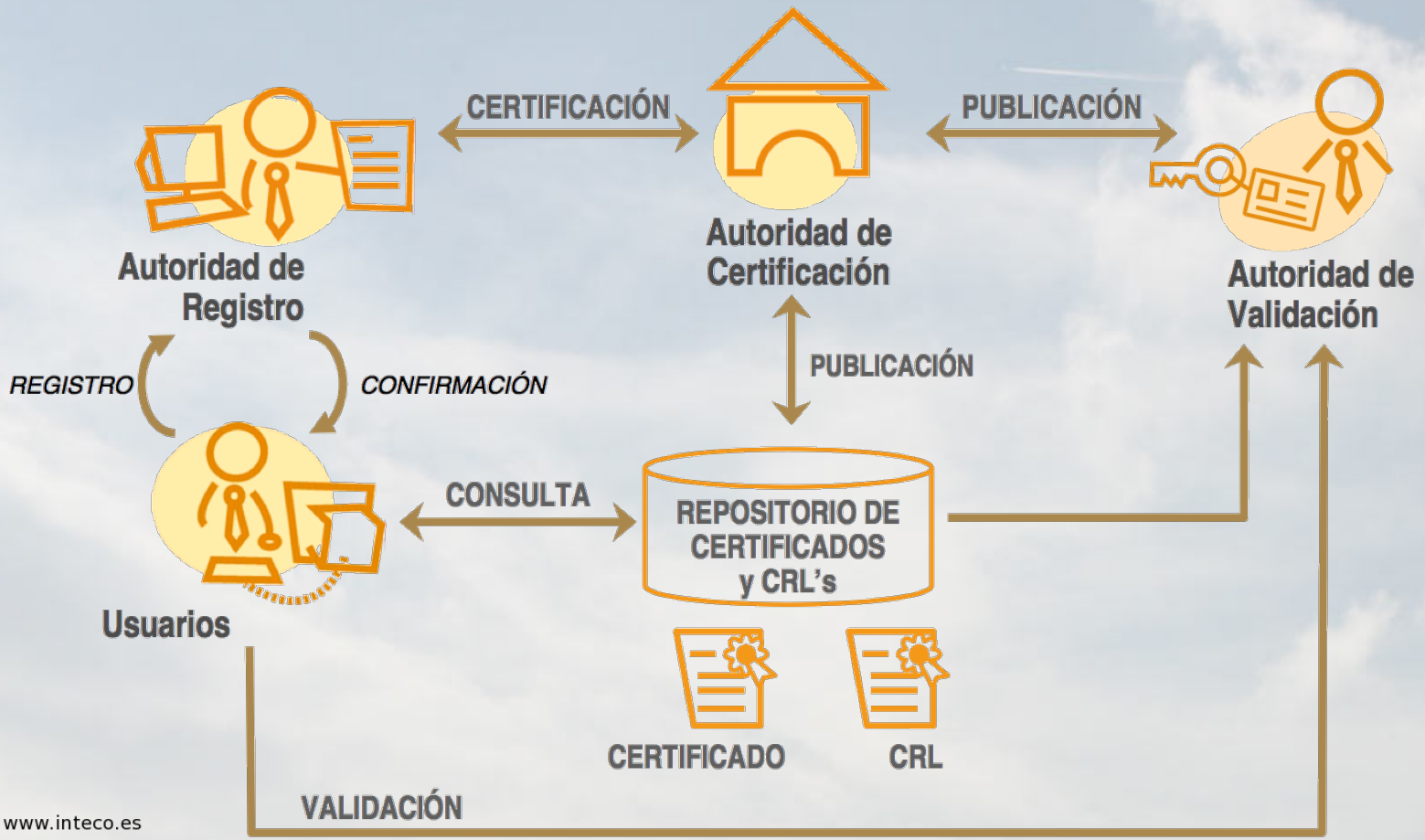
Componentes de este modelo:

- **Autoridad de certificación** (CA): **emite** y **revoca** los certificados digitales. Componente principal de la PKI. Estructura jerárquica de las CA's subordinadas a una CA root.



- **Autoridad de registro** (RA): gestiona el **registro** de usuarios, procesa sus peticiones de certificación/revocación de certificados, **verifica los datos** aportados por el solicitante y **autoriza** la asociación entre una clave pública y su titular. NO emite.
- **Repositorio**: para el almacenamiento/recuperación de certificados y listas de revocación de certificados (CRLs)
- **Autoridad de Validación** (VA): suministra información *online* acerca del estado de un certificado.
- **Software** para la gestión de certificados (por ejemplo: PKCS)
- **Certification Practice Statement**(CPS, RFC 7382): Política de seguridad en las comunicaciones relacionadas con la gestión de los certificados




CERTIFICACIÓN
PUBLICACIÓN
Autoridad de Registro
Autoridad de Certificación
Autoridad de Validación
REGISTRO
CONFIRMACIÓN
PUBLICACIÓN
CONSULTA
REPOSITORIO DE CERTIFICADOS y CRL's
Usuarios
CERTIFICADO
CRL
VALIDACIÓN
www.inteco.es

Autoridad de Certificación (CA)

Entidad de confianza que asume la responsabilidad de autenticar la información de la identidad que figura en el certificado

- Funciones básicas:
  - Expedición de certificados digitales.
  - Gestión de las listas de revocación.
  - Publicación de sus certificados digitales y correspondiente lista de revocación.
  - Almacenamiento del estado de los certificados expirados que ha expedido.
  - Declaración de prácticas de certificación (CPS)
  - Cumplir *Baseline Requirements*, *CT requirements*,
  - ...
- Proveedores
- Sujeta a errores/fallos



Expedición de certificados

- Certificado para una CA raíz.
  Entidad genera su propio par de claves asimétricas y emite un certificado autofirmado (*self-signed*). *CA offline*



Expedición de certificados

- Certificado para una CA raíz.
  Entidad genera su propio par de claves asimétricas y emite un certificado autofirmado (*self-signed*). *CA offline*
- Certificado para una entidad (CA subordinada/servidor/software)
  Entidad genera su propio par de claves asimétricas y remite una **solicitud a la CA** con la clave pública (enviada por un canal autenticado) para su firma.
  El certificado se distribuye en un fichero `*.crt (*.cer)`



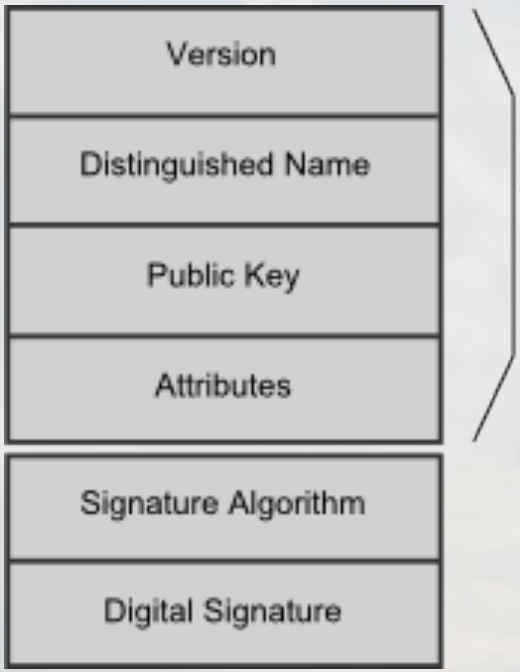
Expedición de certificados

- Certificado para una CA raíz.
  Entidad genera su propio par de claves asimétricas y emite un certificado autofirmado (*self-signed*). *CA offline*
- Certificado para una entidad (CA subordinada/servidor/software)
  Entidad genera su propio par de claves asimétricas y remite una **solicitud a la CA** con la clave pública (enviada por un canal autenticado) para su firma.
  El certificado se distribuye en un fichero `*.crt (*.cer)`
- Certificado para un usuario (certificado personal)
  Usuario realiza una solicitud a la CA, para generar las claves asimétricas y emitir el certificado:
  - Archivos PKCS#12: la clave privada más el certificado se remiten en un fichero `*.p12/pfx`
  - Soporte físico: las claves se generan dentro de un dispositivo criptográfico seguro que se entrega al usuario (*smartcard*, dnie...)



Certificate Signing Request CSR (RFC 2986)

No es un certificado, es un formato de mensaje para solicitar a una CA la certificación de la clave pública de una entidad. Contiene la clave pública junto con la información de la entidad y está firmada con la clave privada de la entidad solicitante.
El formato más utilizado es **PKCS#10** definido por RSA



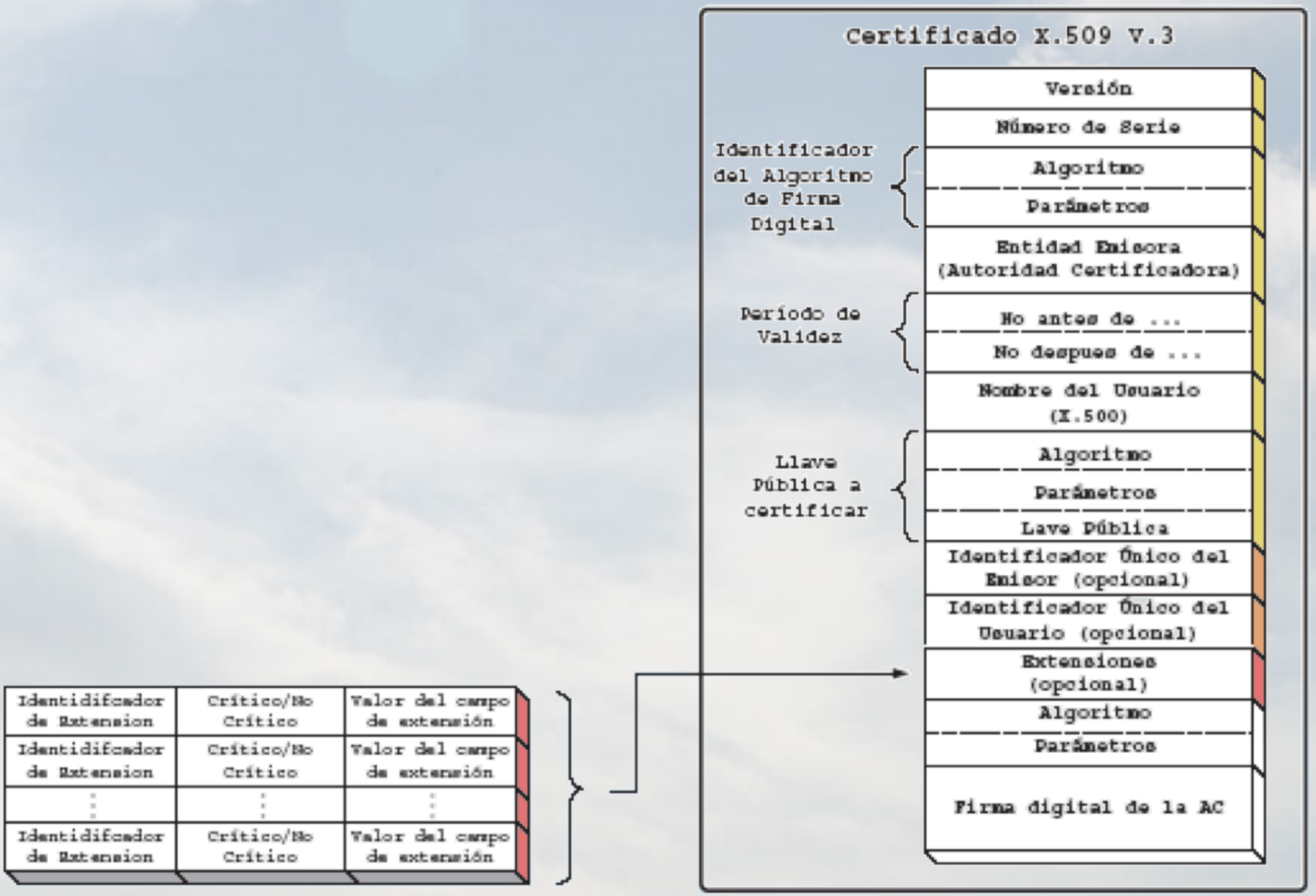

```
Certificate Request:
    Data:
        Version: 0 (0x0)
        Subject: C=ES, ST=GIPUZKOA, L=DONOSTIA, O=SRDSI, OU=LABS, CN=CA-SRDSI/email
Address=ca_master@srdsi.labs
        Subject Public Key Info:
            Public Key Algorithm: rsaEncryption
                Public-Key: (1024 bit)
                Modulus:
                    00:cc:af:ab:be:fc:7c:84:21:51:23:a1:13:07:b9:
                    aa:b4:86:7d:32:44:39:cd:96:9b:b7:9d:38:6e:d9:
                    c4:48:1a:db:ac:29:95:a1:a4:4b:07:6c:00:78:11:
                    97:1e:f0:47:88:bb:ed:13:39:a3:37:04:9e:d9:f1:
                    75:ac:8e:65:e6:07:a8:14:6b:48:26:68:a7:5b:7e:
                    6c:57:aa:94:14:54:cf:ea:0c:c5:3f:3e:d0:9c:10:
                    31:6b:e1:6a:0d:54:29:04:8f:dd:99:45:6c:96:d3:
                    50:0a:ca:b8:d6:92:cd:29:ea:8f:8c:ba:92:7d:d9:
                    fb:f5:96:23:c9:4a:31:24:af
                Exponent: 65537 (0x10001)
        Attributes:
            a0:00
    Signature Algorithm: sha1WithRSAEncryption
         12:53:c7:70:94:ba:69:34:47:b1:5f:50:90:93:79:8c:33:3b:
         a2:22:72:d4:8e:17:6f:7b:5d:38:9b:db:8b:82:6a:f8:76:06:
         d9:21:3a:bb:24:c4:2e:ab:9b:3e:3b:2a:46:71:a6:57:4b:2d:
         78:9c:c9:ed:e1:02:ae:65:e2:cc:80:90:0f:6f:d0:2b:54:81:
         16:d5:1c:f2:4f:17:46:98:a0:1b:00:51:c6:65:12:38:cf:01:
         22:bb:14:e3:64:b3:54:2c:14:29:9b:25:56:fe:ef:67:46:5d:
         7f:27:6a:cf:c6:2f:46:29:e0:86:4a:0c:98:e8:aa:38:74:fa:
         4a:1e
-----BEGIN CERTIFICATE REQUEST-----
MIIByzCCATQCAQAwgYoxCzAJBgNVBAYTAkVTMREwDwYDVQQIDAhHSVBVWktPQTER
MA8GA1UEBwwIRE9OT1NUSUExDjAMBgNVBAoMBVNSRFNJMQ0wCwYDVQQLDARMQUJT
MREwDwYDVQQDDAhDQS1TUkRTSTEjMCEGCSqGSIb3DQEJARYUY2FfbWFzdGVyQHNy
ZHNpLmxhYnMwgZ8wDQYJKoZIhvcNAQEBBQADgY0AMIGJAoGBAMyvq778fIQhUSOh
Ewe5qrSGfTJE0c2Wm7edOG7ZxEga26wplaGkSwdsAHgRlx7wR4i77RM5ozcEntnx
day0ZeYHqBRrSCZop1t+bFeqlBRUz+oMxT8+0JwQMWvhag1UKQSP3ZlFbJbTUArK
uNaSzSnqj4y6kn3Z+/WWI8lKMSSvAgMBAAGgADANBgkqhkiG9w0BAQUFAAOBgQAS
U8dwlLppNEexX1CQk3mMMzuiInLUjhdve104m9uLgmr4dgbZITq7JMQuq5s+OypG
caZXSy14nMnt4QKuZeLMgJAPb9ArVIEW1RzyTxdGmKAbAFHGZRI4zwEiuxTjZLNU
LBQpmyVW/u9nRl1/J2rPxi9GKeCGSgyY6Ko4dPpKHg==
-----END CERTIFICATE REQUEST-----
```

Certificado Digital ITU-T X.509 (ISO/IEC 9594-8:2017 - RFC 5280)

Según norma X.509 v3 de ISO/IEC y ANSI X9, contiene:

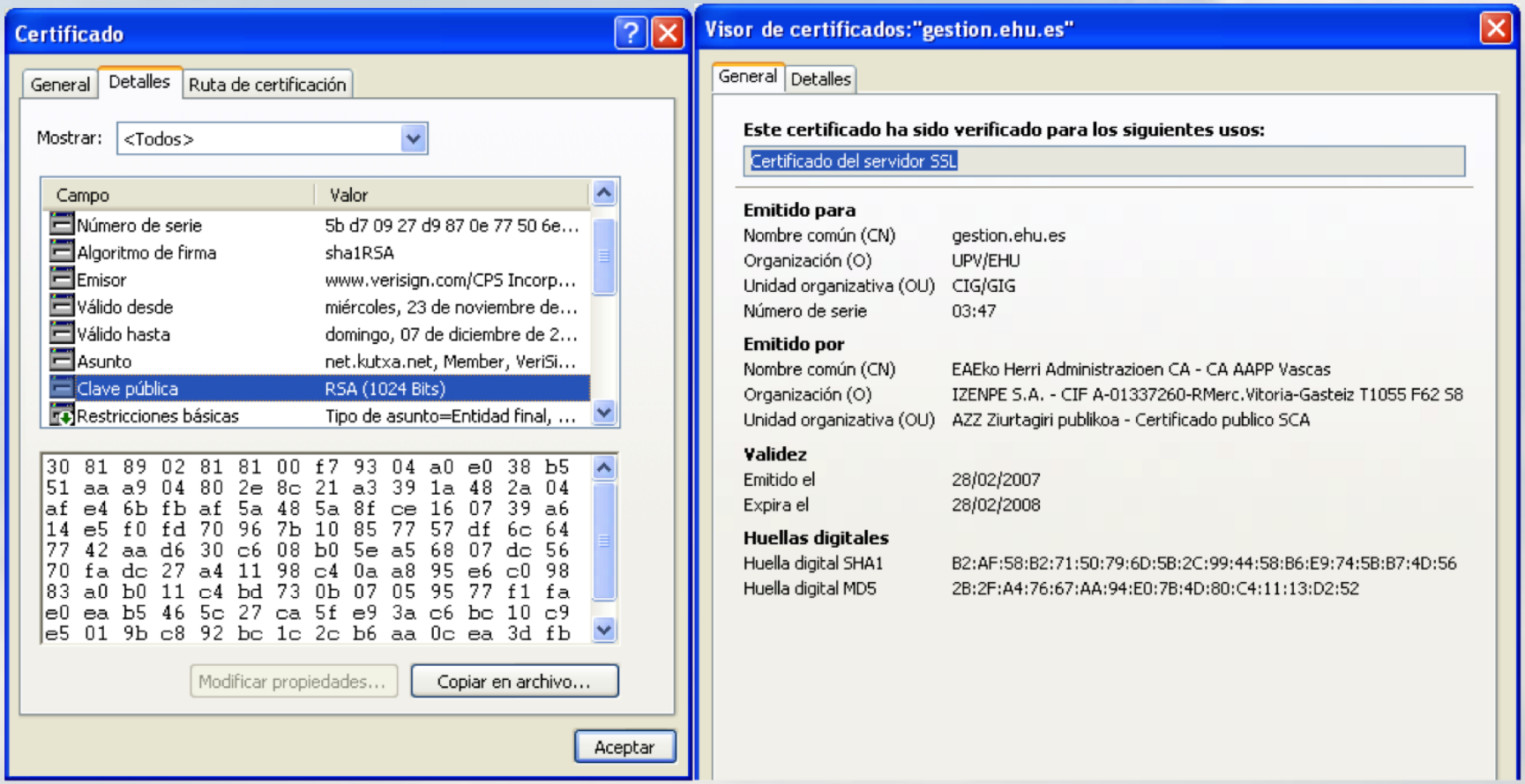
- **Clave pública del usuario**
- **Nombre del usuario** (**C**ommon **N**ame –> **S**ubject**A**lternative**N**ame)
- **Firma del emisor (CA)**
- Fecha de caducidad de la clave
- Nombre de la autoridad de certificación
- Versión del certificado
- Extensiones para atributos adicionales (RFC 5280)
- ...





fuente: williamstallings.com

Ejemplo


Certificado
General
Detalles
Ruta de certificación
Mostrar:
<Todos>
Campo
Valor
Número de serie
5b d7 09 27 d9 87 0e 77 50 6e...
Algoritmo de firma
sha1RSA
Emisor
www.verisign.com/CPS Incorp...
Válido desde
miércoles, 23 de noviembre de...
Válido hasta
domingo, 07 de diciembre de 2...
Asunto
net.kutxa.net, Member, VeriSi...
Clave pública
RSA (1024 Bits)
Restricciones básicas
Tipo de asunto=Entidad final, ...
30 81 89 02 81 81 00 f7 93 04 a0 e0 38 b5
51 aa a9 04 80 2e 8c 21 a3 39 1a 48 2a 04
af e4 6b fb af 5a 48 5a 8f ce 16 07 39 a6
14 e5 f0 fd 70 96 7b 10 85 77 57 df 6c 64
77 42 aa d6 30 c6 08 b0 5e a5 68 07 dc 56
70 fa dc 27 a4 11 98 c4 0a a8 95 e6 c0 98
83 a0 b0 11 c4 bd 73 0b 07 05 95 77 f1 fa
e0 ea b5 46 5c 27 ca 5f e9 3a c6 bc 10 c9
e5 01 9b c8 92 bc 1c 2c b6 aa 0c ea 3d fb
Modificar propiedades...
Copiar en archivo...
Aceptar
Visor de certificados:"gestion.ehu.es"
General
Detalles
Este certificado ha sido verificado para los siguientes usos:
Certificado del servidor SSL
Emitido para
Nombre común (CN) gestion.ehu.es
Organización (O) UPV/EHU
Unidad organizativa (OU) CIG/GIG
Número de serie 03:47
Emitido por
Nombre común (CN) EAEko Herri Administrazioen CA - CA AAPP Vascas
Organización (O) IZENPE S.A. - CIF A-01337260-RMerc.Vitoria-Gasteiz T1055 F62 S8
Unidad organizativa (OU) AZZ Ziurtagiri publikoa - Certificado publico SCA
Validez
Emitido el 28/02/2007
Expira el 28/02/2008
Huellas digitales
Huella digital SHA1 B2:AF:58:B2:71:50:79:6D:5B:2C:99:44:58:B6:E9:74:5B:B7:4D:56
Huella digital MD5 2B:2F:A4:76:67:AA:94:E0:7B:4D:80:C4:11:13:D2:52



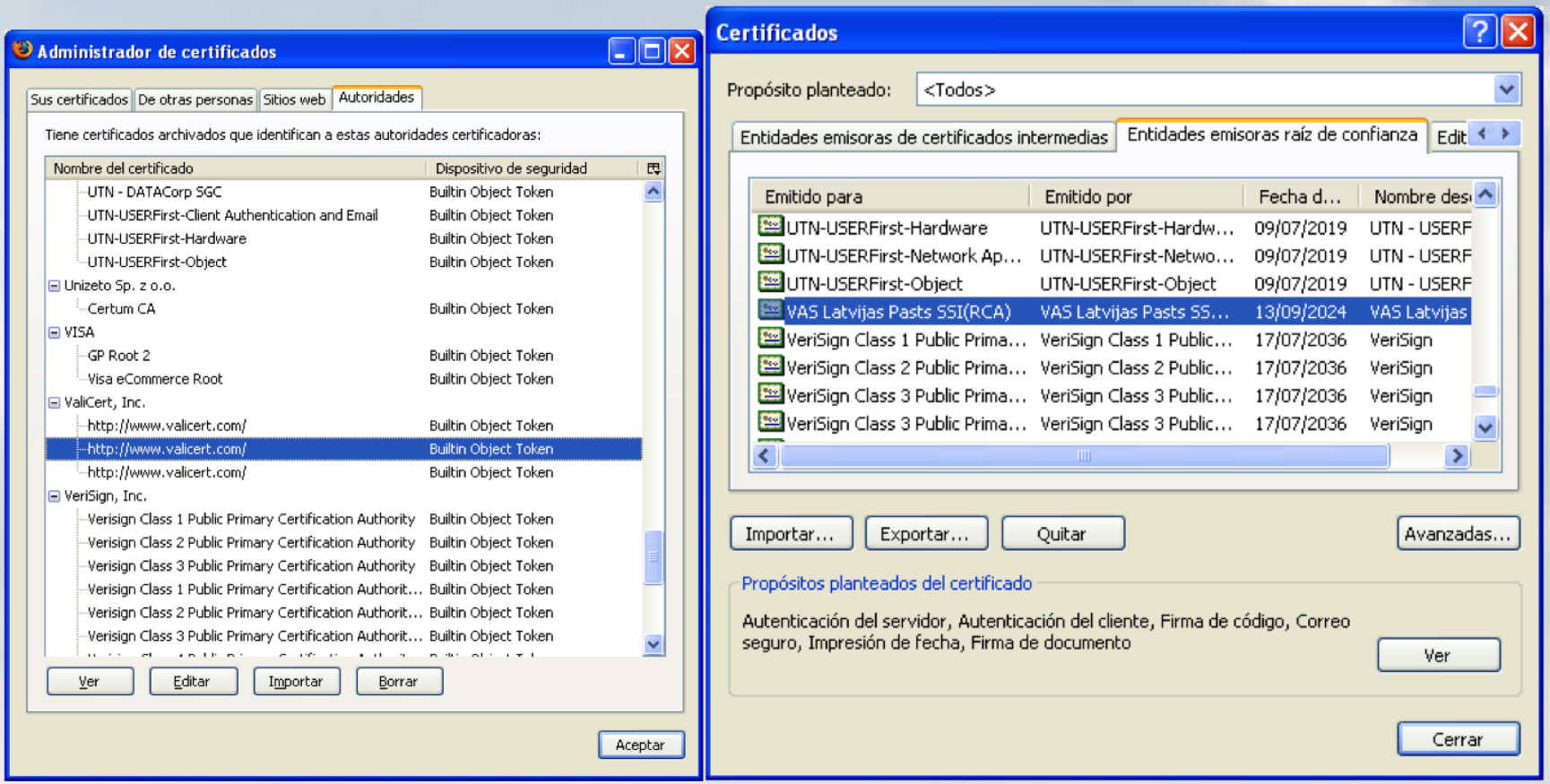
Validación de certificados

Verificar la validez de un certificado

- Autenticación del certificado
  - Dominio correcto (SAN vs CN)
  - Camino de certificación verificado (*path construction + path validation*)
- Dentro del periodo de validez
- Comprobar todas las extensiones críticas:
  - Uso dentro del contexto para el que fue emitido *(key usage)*
  - Longitud del camino de certificación
  - ...
- Estado de revocación del certificado(VA)
  - Offline, con la descarga de CRLs por parte del usuario
  - Online, mediante el protocolo OCSP (*Online Certification Status Protocol*)



Certificados de CA



Mozilla Root Store Policy, *Chrome Root Program Policy*

Firefox CA root list, *Microsoft CA root list*, *Apple CA root list*

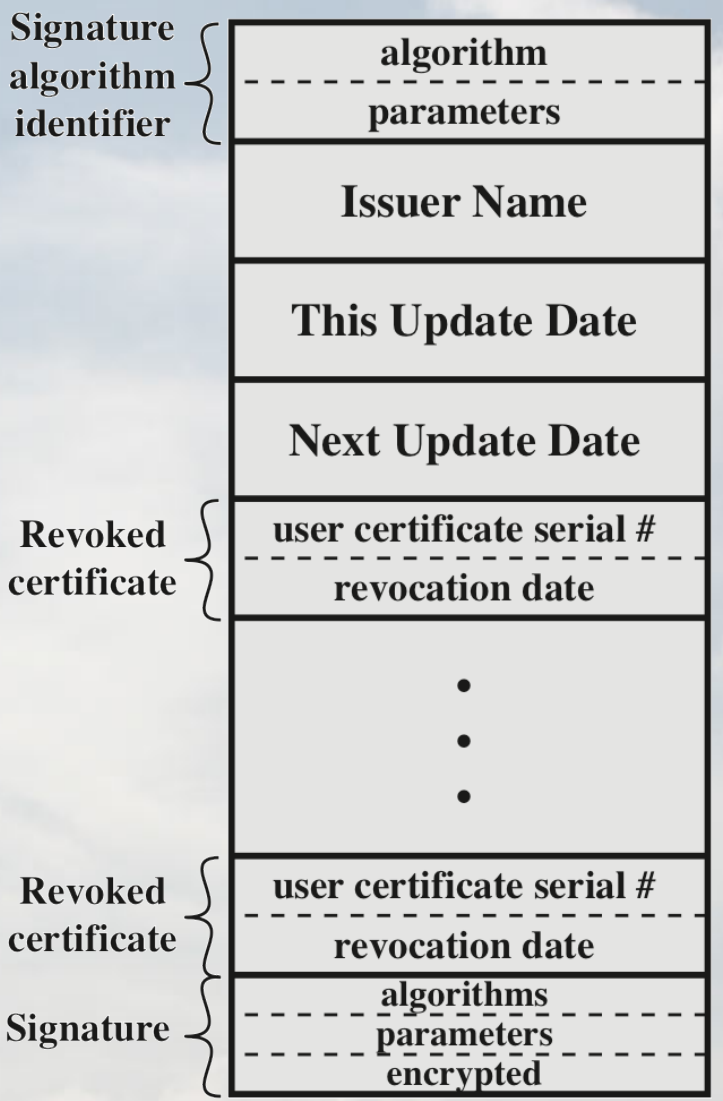
No válidos


Visor de certificados:"Builtin Object Token:Verisign Class 3 Public Primary ...
General
Detalles
No se ha podido verificar este certificado porque se ha firmado usando un algoritmo de firma que fue desactivado porque es inseguro.
Emitido para
Nombre común (CN) <No es parte de un certificado>
Organización (O) VeriSign, Inc.
Unidad organizativa (OU) Class 3 Public Primary Certification Authority
Número de serie 70:BA:E4:1D:10:D9:29:34:B6:38:CA:7B:03:CC:BA:BF
Emitido por
Nombre común (CN) <No es parte de un certificado>
Organización (O) VeriSign, Inc.
Unidad organizativa (OU) Class 3 Public Primary Certification Authority
Validez
Emitido el 29/01/96
Caduca el 02/08/28
Huellas digitales
Huella digital SHA1 74:2C:31:92:E6:07:E4:24:EB:45:49:54:2B:E1:BB:C5:3E:61:74:E2
Huella digital MD5 10:FC:63:5D:F6:26:3E:0D:F3:25:BE:5F:79:CD:67:67
Cerrar


Visor de certificados:"*.EDUCACION.ES"
General
Detalles
No se pudo verificar este certificado porque ha caducado.
Emitido para
Nombre común (CN) *.EDUCACION.ES
Organización (O) FNMT
Unidad organizativa (OU) FNMT Clase 2 CA
Número de serie 3C:AD:63:E5
Emitido por
Nombre común (CN) <No es parte de un certificado>
Organización (O) FNMT
Unidad organizativa (OU) FNMT Clase 2 CA
Validez
Emitido el 20/04/09
Caduca el 20/04/13
Huellas digitales
Huella digital SHA1 EB:DB:82:FC:E0:D2:F2:8A:8C:13:13:55:80:8D:B4:78:7C:10:99:23
Huella digital MD5 5A:A0:2E:4A:63:E8:F4:95:60:DC:22:E1:9A:EE:00:9C
Cerrar

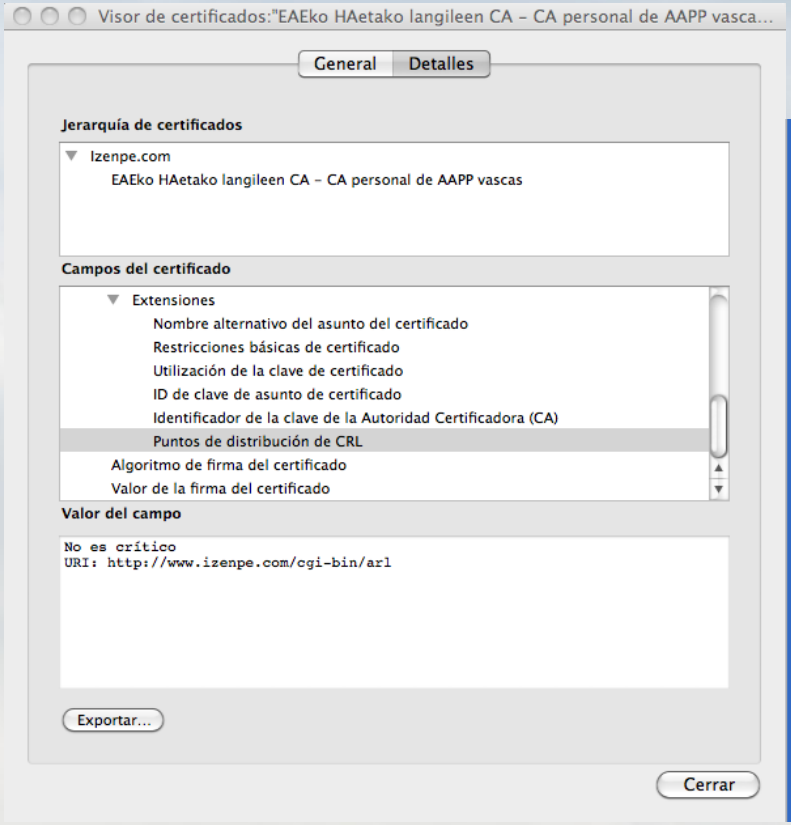
Lista de revocación de certificados (CRL) (RFC 5280)

Cada CA debe mantener una lista firmada de los certificados emitidos por ella (no caducados) que han sido revocados.
X.509 v1/v2 CRL
revocation check



fuente: williamstallings.com

Ejemplo



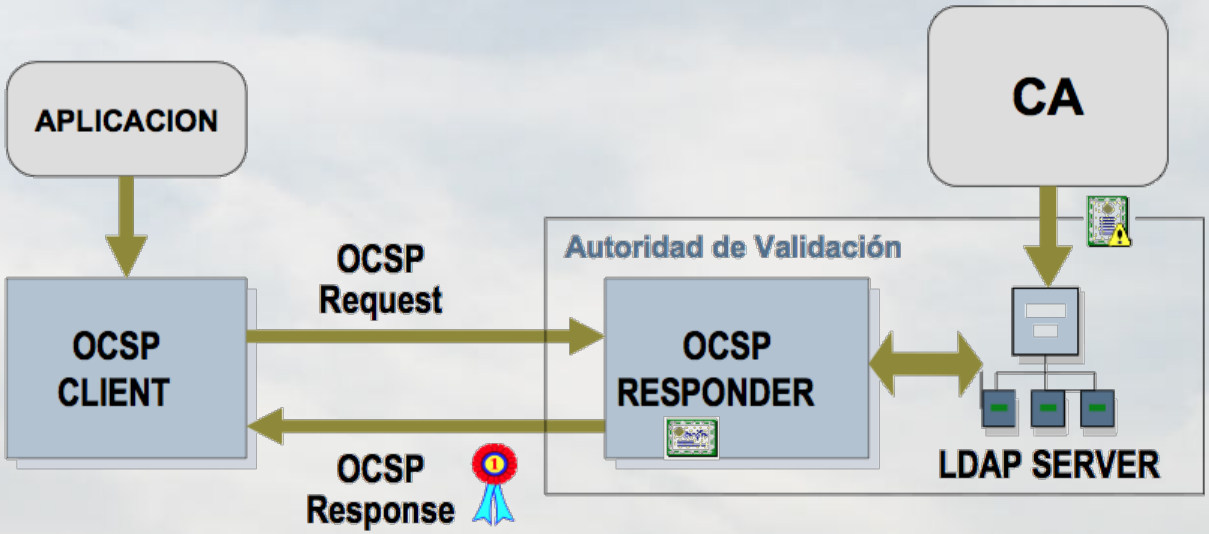

```
Certificate Revocation List (CRL):
        Version 2 (0x1)
        Signature Algorithm: sha1WithRSAEncryption
        Issuer: /C=ES/O=IZENPE S.A. - CIF A-01337260-RMerc.Vit
oria-Gasteiz T1055 F62 S8/L=Avda del Mediterraneo Etorbidea 3
- 01010 Vitoria-Gasteiz/CN=Izenpe.com/emailAddress=Info@izenpe
.com
        Last Update: Jun 19 09:43:33 2013 GMT
        Next Update: Jun 19 09:43:33 2014 GMT
        CRL extensions:
            X509v3 CRL Number:
                16
            X509v3 Authority Key Identifier:
                keyid:EA:56:4F:EC:3C:83:A1:14:88:78:81:B2:2B:0
5:22:C0:07:41:5B:42
                DirName:/C=ES/O=IZENPE S.A. - CIF A-01337260-R
Merc.Vitoria-Gasteiz T1055 F62 S8/L=Avda del Mediterraneo Etor
bidea 3 - 01010 Vitoria-Gasteiz/CN=Izenpe.com/emailAddress=Inf
o@izenpe.com
                serial:01

            X509v3 Issuing Distrubution Point: critical
                0'.%.#.!http://www.izenpe.com/cgi-bin/arl
No Revoked Certificates.
    Signature Algorithm: sha1WithRSAEncryption
        70:09:d2:b2:51:e3:b3:d2:94:66:c6:72:26:6b:17:25:0d:23:
        b2:af:0c:bc:10:21:28:ee:f1:22:c3:61:11:ee:5a:e3:5b:b6:
```

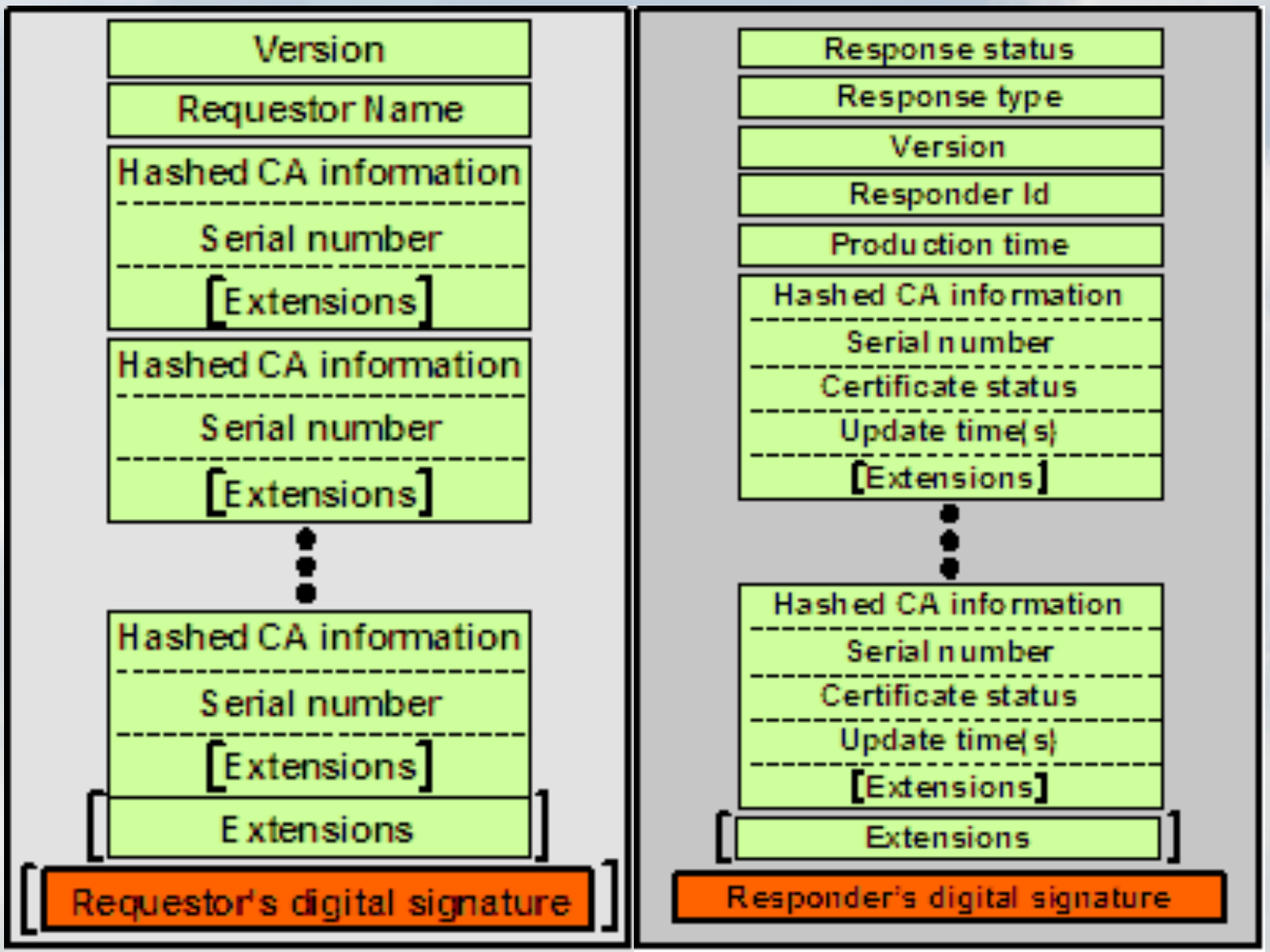


OCSP *(Online Certificate Status Protocol)* (RFC 6960, RFC 6066)

Confirmación *online* del estado de revocación de un certificado

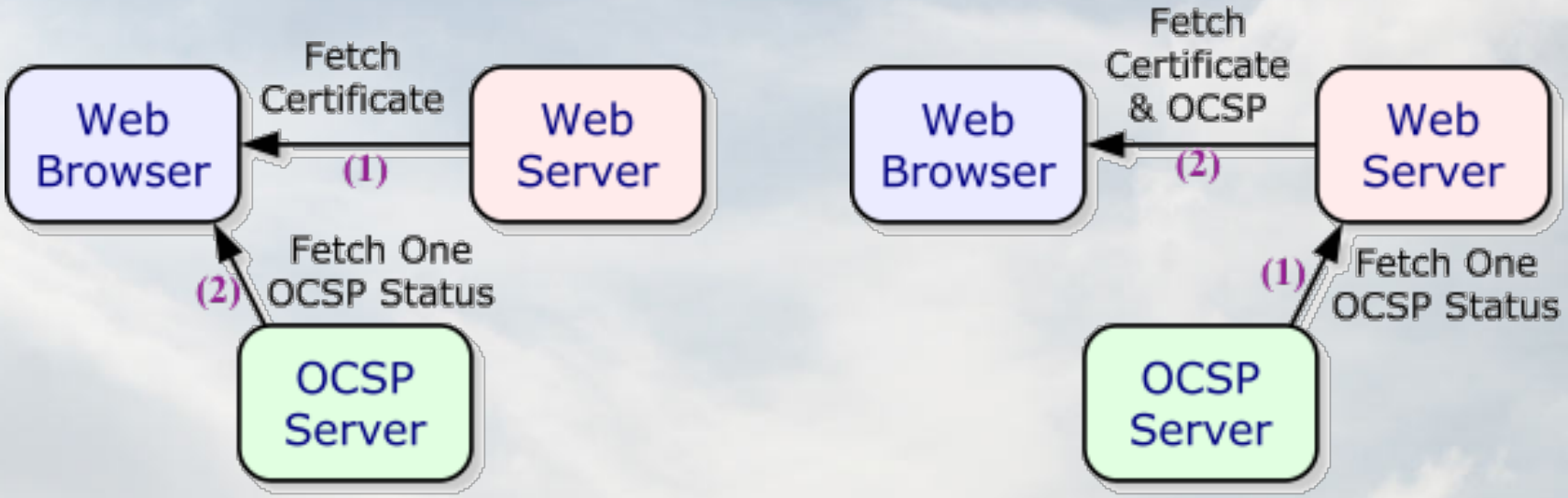


fuente: es.slideshare.net/manuelbarcell/t04-01-pki



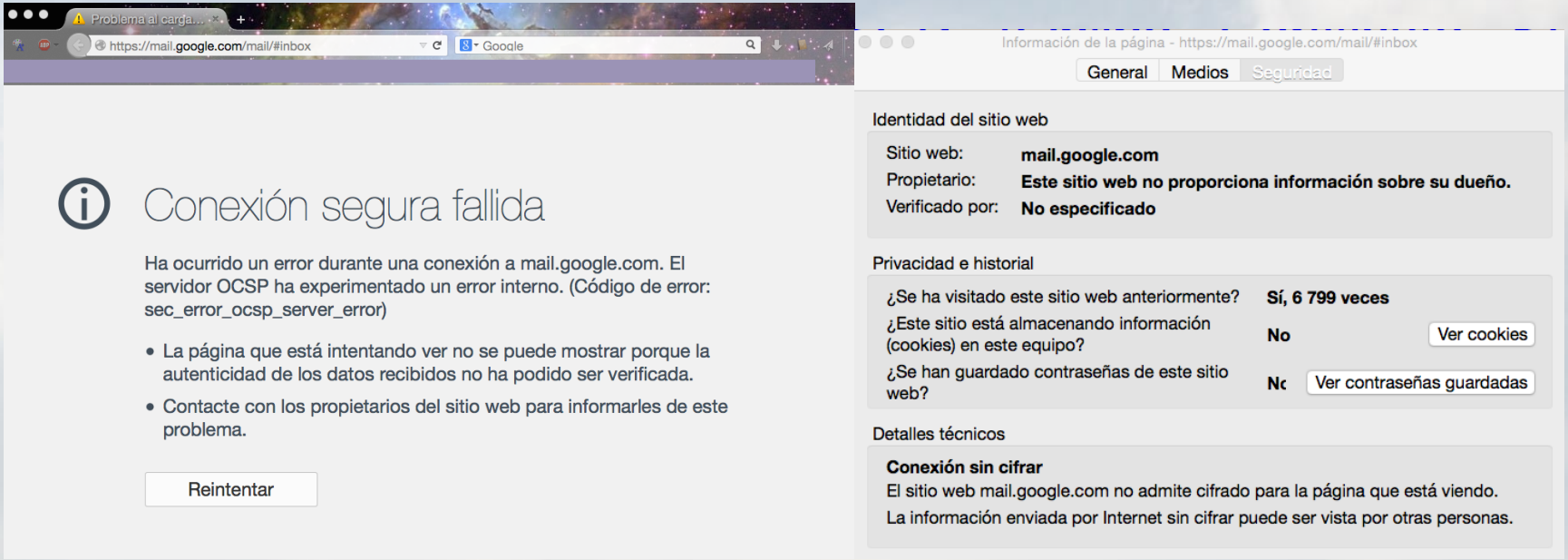
fuente: www.x500standard.com/index.php?n=X509W.OCSP

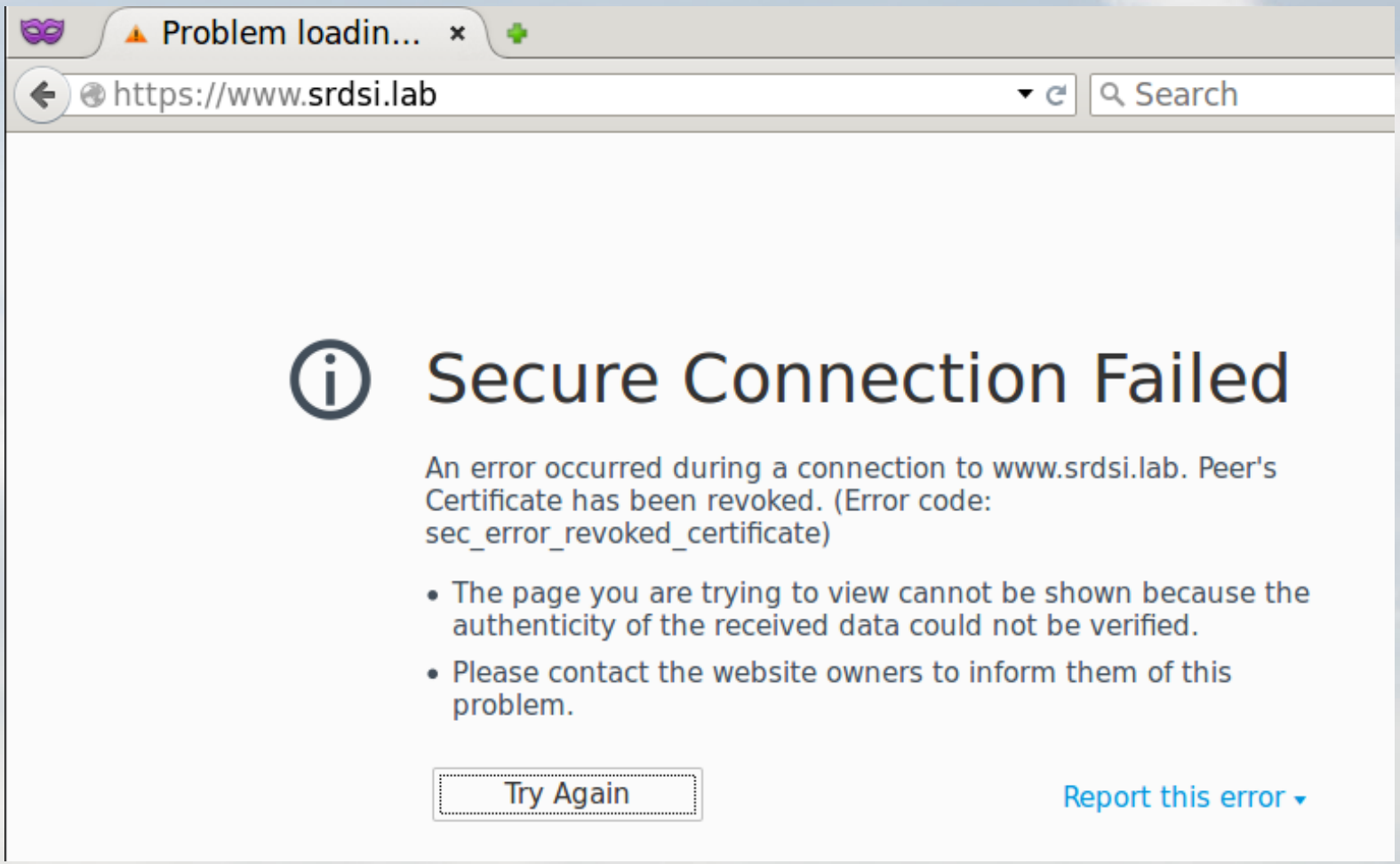
OCSP Stapling (RFC 6066, 6961, 8446)



Regular OCSP vs OCSP Stapling

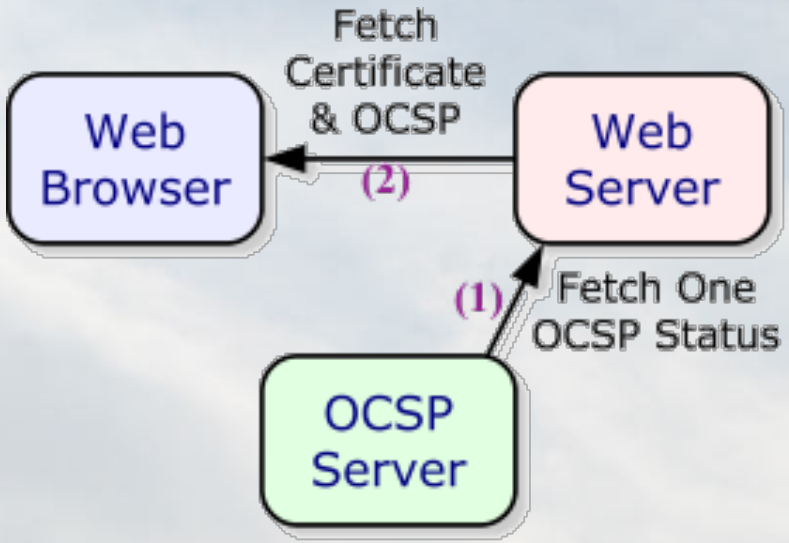
fuente: www.grc.com/revocation/ocsp-must-staple.htm


Problema al carga...
https://mail.google.com/mail/#inbox
Google
Conexión segura fallida
Ha ocurrido un error durante una conexión a mail.google.com. El servidor OCSP ha experimentado un error interno. (Código de error: sec_error_ocsp_server_error)
• La página que está intentando ver no se puede mostrar porque la autenticidad de los datos recibidos no ha podido ser verificada.
• Contacte con los propietarios del sitio web para informarles de este problema.
Reintentar
Información de la página - https://mail.google.com/mail/#inbox
General
Medios
Seguridad
Identidad del sitio web
Sitio web: mail.google.com
Propietario: Este sitio web no proporciona información sobre su dueño.
Verificado por: No especificado
Privacidad e historial
¿Se ha visitado este sitio web anteriormente? Sí, 6 799 veces
¿Este sitio está almacenando información (cookies) en este equipo? No
Ver cookies
¿Se han guardado contraseñas de este sitio web? Nc
Ver contraseñas guardadas
Detalles técnicos
Conexión sin cifrar
El sitio web mail.google.com no admite cifrado para la página que está viendo.
La información enviada por Internet sin cifrar puede ser vista por otras personas.


Problem loadin...
https://www.srdsi.lab
Search
Secure Connection Failed
An error occurred during a connection to www.srdsi.lab. Peer's Certificate has been revoked. (Error code: sec_error_revoked_certificate)
• The page you are trying to view cannot be shown because the authenticity of the received data could not be verified.
• Please contact the website owners to inform them of this problem.
Try Again
Report this error

OCSP Must-Staple (RFC 7633)

Es una extensión del certificado X509



fuente: www.grc.com/revocation/ocsp-must-staple.htm

Cuando un cliente recibe un certificado con esta extensión, el servidor debe incluir la respuesta OCSP junto al certificado sino el cliente lo rechazará (*hard-failure*)



OCSP en el futuro

Desaparición en PKI públicas:
Un certificado con la extensión *Must-staple* puede equipararse a un certificado con el mismo tiempo de vida que la respuesta OCSP incorporada (***short-lived certificates***). Según las normativas oficiales, un certificado que expira en 7 días o menos no necesita incluir ningún mecanismo de revocación. No hay ningún beneficio de seguridad para realizar la verificación de la revocación en estos certificados.

- Revocation Checking in Firefox
- Short-lived certificates, Solving the revocation gap with short-lived certificates
- (RFC 9608) No revocation available for X.509 certificates (*noRevAvail* certificate extension)

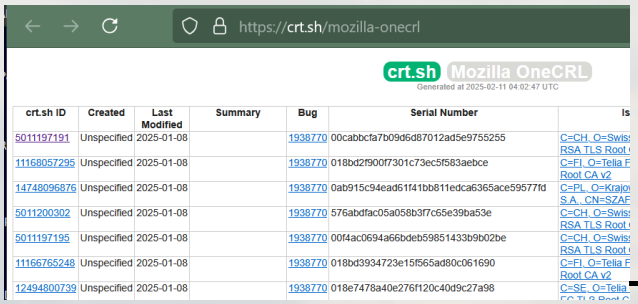
Se mantendrá en PKI privadas, para controles estrictos en tiempo real

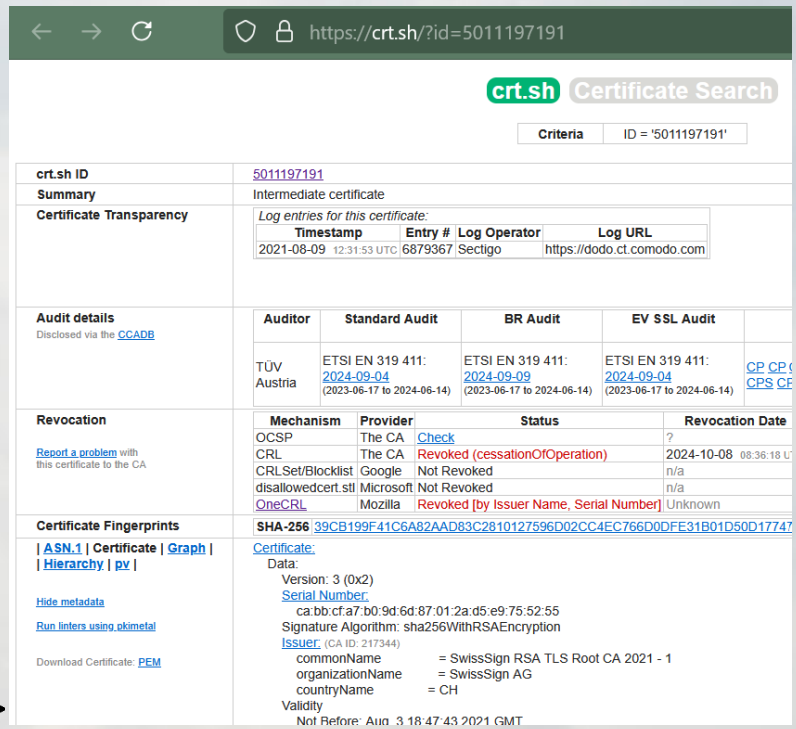


CRLs "revisitadas"

El navegador descarga en segundo plano una base de datos, verifica de forma local y en milisegundos si un certificado es válido, de manera 100 % privada y sin depender de consultas en tiempo real por internet.

- **OneCRL** (Mozilla): Recopila información de revocación de **certificados intermedios de CA** de forma centralizada, para enviarla a los clientes.





- **CRLite**(Mozilla): tecnología que comprime el estado de revocación de todos los certificados en los registros de *Certificate Transparency* (pocos megabytes iniciales (filtros de *Bloom* o *Ribbon*)). Actualizada cada 12 horas (pocos bytes).

  `about:config -> security.pki.crlite_mode 2` (=activo)

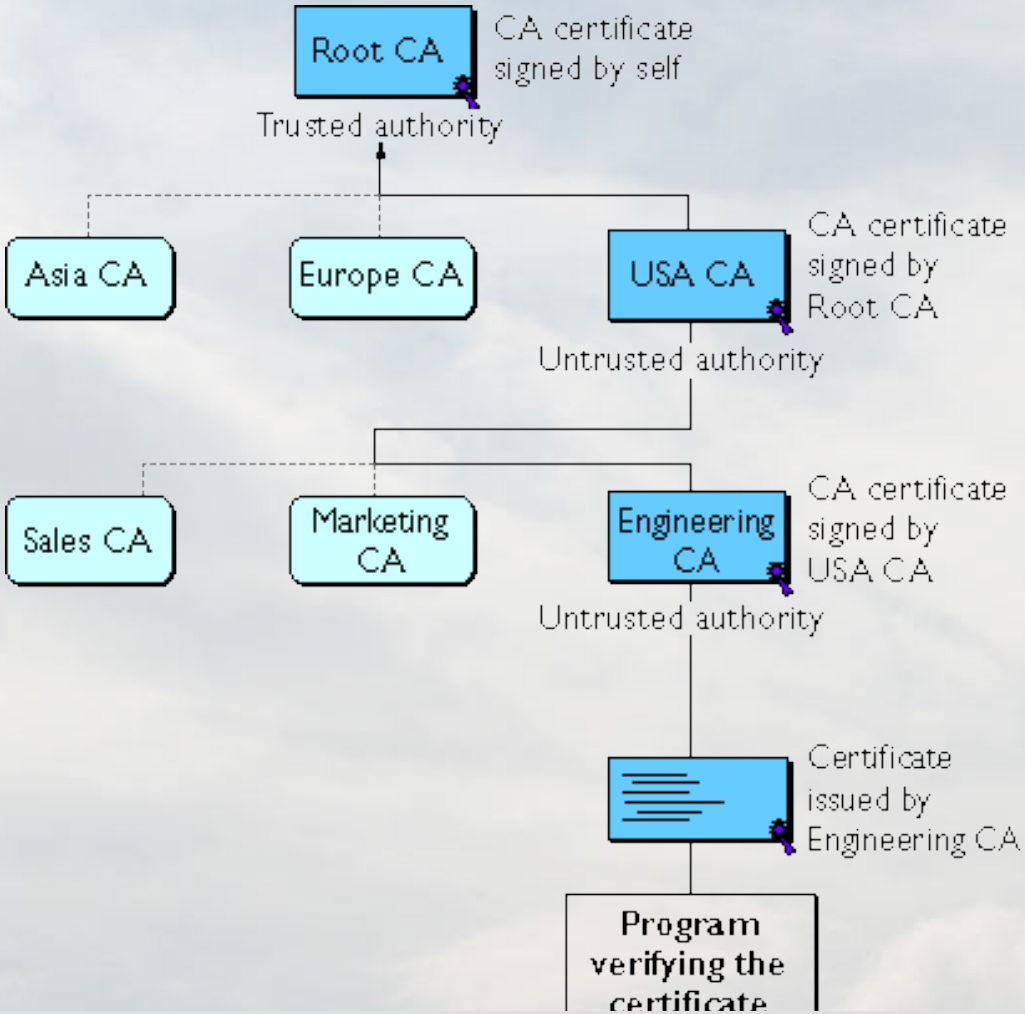
  https://zhul.in/en/2025/10/16/how-s-mozilla-crlite-going-now/

- **CRLSets** (Google): recolecta las CRLs de todas las CA seleccionando solo los certificados revocados más críticos (hackeos masivos, certificados de validación extendida...). Actualizaciones variables.



Camino de certificación (RFC 4158)

Camino desde el certificado de una autoridad de certificación de confianza hasta el certificado presentado (*certificate chains*)

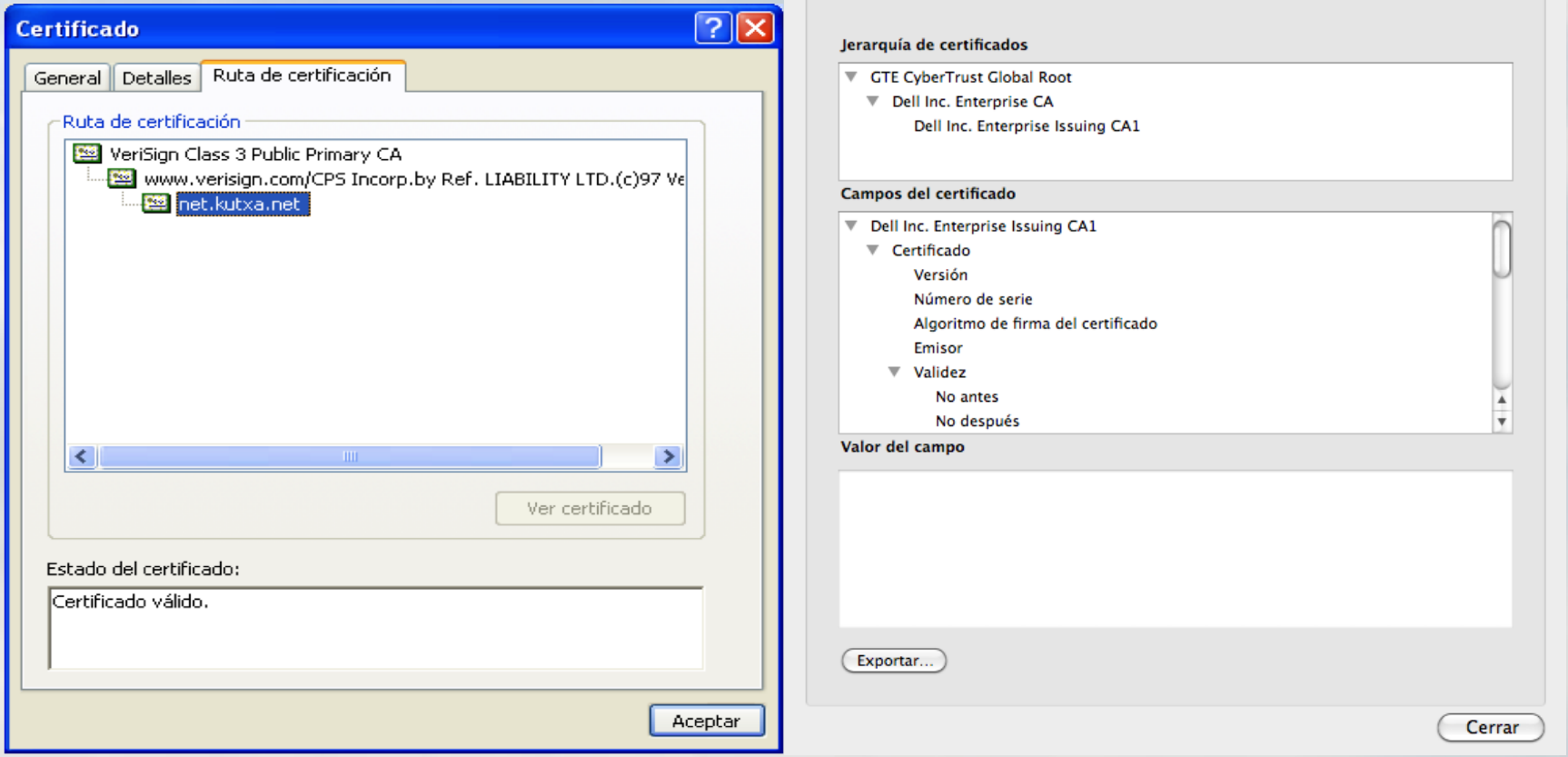


Check validity period and verify that this is signed by Root CA. Since Root CA is trusted, verification stops here.

Check validity period and verify that this is signed by USA CA. Since USA CA is not trusted, check the next certificate.

Check validity period and verify that this is signed by Engineering CA. Since Engineering CA is not trusted, check the next certificate.

Ejemplo



Browsers and certificate validation

ACTIVIDAD

Elegir una CA y realizar un estudio relacionado con la obtención de un certificado para una entidad:

- ¿Qué tipos de certificados emite? ¿usos? *<Selecionar un tipo>*
- ¿Qué pasos hay que realizar?
- ¿Qué documentación es necesaria presentar para su solicitud?
- ¿Cómo se verifica la identidad del solicitante?
- ¿Cuánto cuesta un certificado? ¿Periodo de validez?
- ¿Cómo remiten el certificado (y la clave privada)?
- ¿Cada cuánto emiten CRLs? y/o ¿Usan OCSP? ¿OCSP *Must-staple*? ¿*Short-lived certificates*?
- ¿Tienen disponible públicamente su CPS?
- ¿Tienen publicado/acceso a su certificado *CA root*?
- ...

Autoridades de Certificación en España:

- FNMT (Fábrica Nacional de Moneda y Timbre)
- Izenpe

Top 10 SSL CAs

